

PIEDPIN

Let's try CISSP!

なぜCISSPを学ぶのか

- ✓ CISSP(Certified Information Systems Security Professional)とは、世界標準の**セキュリティ・プロフェッショナル認定**です。
- ✓ (ISC)²（国際情報システムセキュリティ認証コンソーシアム、International Information Systems Security Certification Consortium）が認定を行っています。
- ✓ 情報セキュリティ専門家が共通言語として利用している『(ISC)² CISSP CBK』を理解している者に与えられる資格です。
- ✓ 2004年6月に、米国規格協会（ANSI）より**ISO/IEC17024**の認証を受け、信頼度がより高くなりました。（https://japan.isc2.org/cissp_about.html）
- ✓ 2022年7月1日現在、日本のCISSPは**3,699**人です。

(ISC)² が展開する資格ソリューション



国際的に認められた情報セキュリティ・プロフェッショナル認定資格です。米国規格協会（ANSI）よりISO/IEC17024の認証を受けた。



ベンダーフリー・カントリーフリーの情報セキュリティの資格です。情報セキュリティに従事しないが、組織を理解し、適切なコミュニケーションを行う。



クラウドサービスを安全に利用するために必要な知識を体系化した資格です。



ソフトウェアの脆弱性に端を発したセキュリティインシデントの増加や、政府や重要インフラにおけるセキュアなソフトウェアニーズに対応する資格です。

(ISC)² CISSP CBK ドメイン



ドメイン 1
セキュリティとリスク
マネジメント



ドメイン 2
資産のセキュリティ



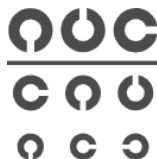
ドメイン 3
セキュリティアーキ
テクチャとエンジニ
アリング



ドメイン 4
通信とネットワー
クのセキュリティ



ドメイン 5
アイデンティティと
アクセスの管理



ドメイン 6
セキュリティの評
価とテスト



ドメイン 7
セキュリティの運用



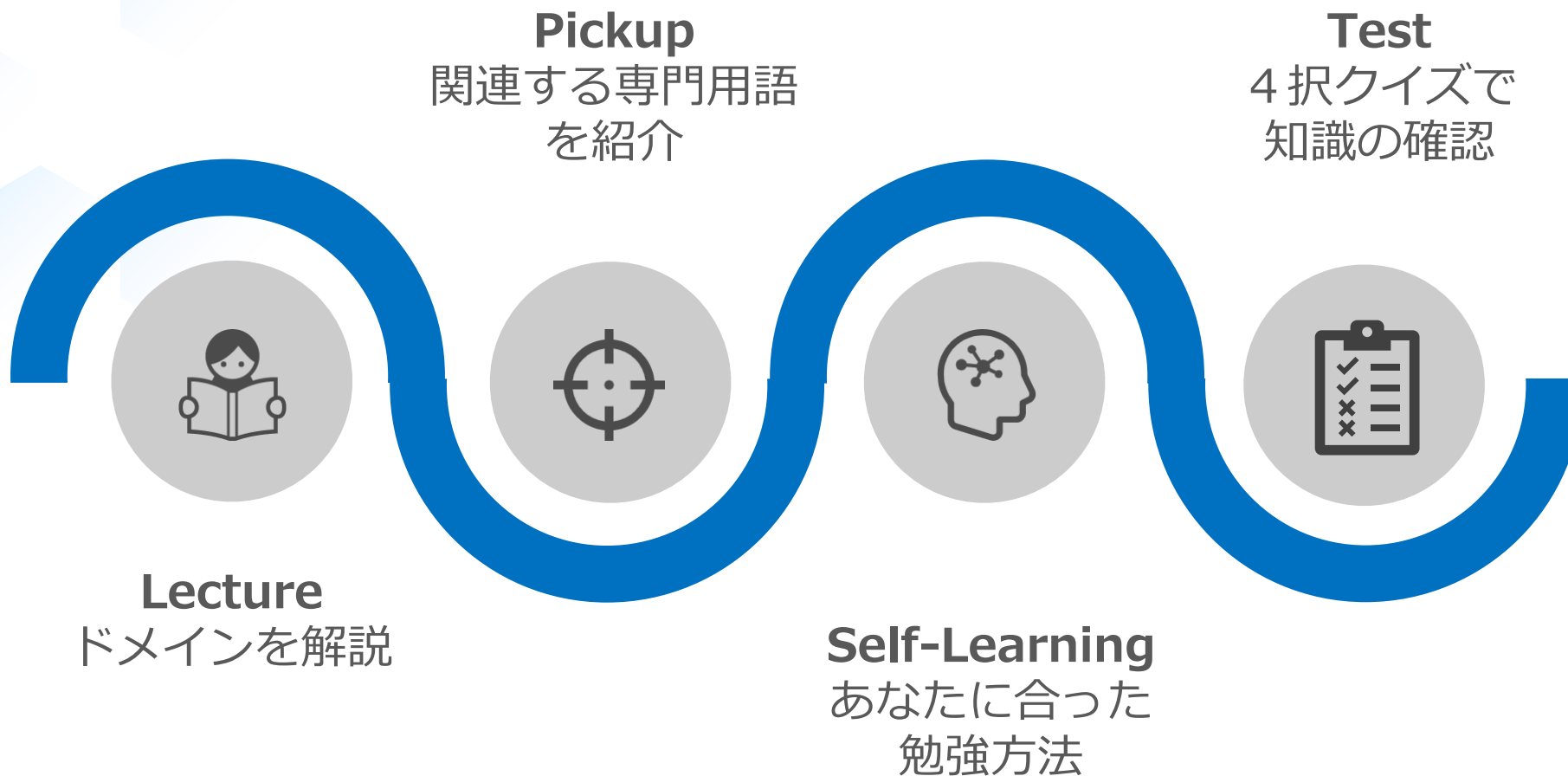
ドメイン 8
ソフトウェア開発
セキュリティ

あなたのゴールと本レッスンの内容

- ✓ 情報セキュリティ初心者のために設計されたCISSP講座
経験者からすると“当たり前”と感じる内容も含まれます。
- ✓ 本レッスンの対象は、CBKのドメイン 1 です。
他のドメインのレッスンは対象外となります。
- ✓ CISSP合格のためのアップグレードが必要です。
現代のセキュリティの関心、流行、考え方を織り込みます。



レッスンの流れ



ドメイン別試験比重



ドメイン 1
セキュリティと
リスクマネジメント

16%



ドメイン 2
資産のセキュリティ

10%



ドメイン 3
セキュリティアーキテク
チャとエンジニアリング

13%



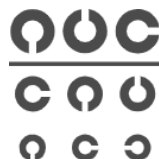
ドメイン 4
通信とネットワーク
のセキュリティ

13%



ドメイン 5
アイデンティティと
アクセスの管理

13%



ドメイン 6
セキュリティの評価
とテスト

12%



ドメイン 7
セキュリティの運用

13%



ドメイン 8
ソフトウェア開発
セキュリティ

10%



職業倫理

職業倫理

(ISC)²職業倫理規定

● 倫理の必要性

倫理

- 倫理は、コンピューター技術に対して否定的な側面を持ちません。
- 倫理を学ぶ目的は、倫理的な観点から技術促進を妨げるものではなく、倫理的な問題に直面するにあたって、指針を定式化し正当化することです。

(ISC)² 職業倫理規定

- (ISC)²も資格取得者に対して倫理規定を提示しています。
- 試験を受ける前に倫理規定を理解していることを確認されます。

(ISC)²倫理規約の序文

社会の安全性を高め、当事者の責務および相互の義務を果たすには、最高レベルの倫理行動規範に従う、もしくは従う姿勢を示す必要がある。よって、当倫理規約の規律を厳守することが資格認定の条件となる。

(ISC)²倫理規約の規律

- ① 社会、一般大衆の福利、およびインフラを保護する。
- ② 法律に違わず、公正かつ誠実に責任を持って行動する。
- ③ 当事者に対して、十分かつ適切なサービスを提供する。
- ④ 専門知識を高め、維持する。

(<https://japan.isc2.org/files/codeofethics.pdf>)

職業倫理

組織の倫理規定

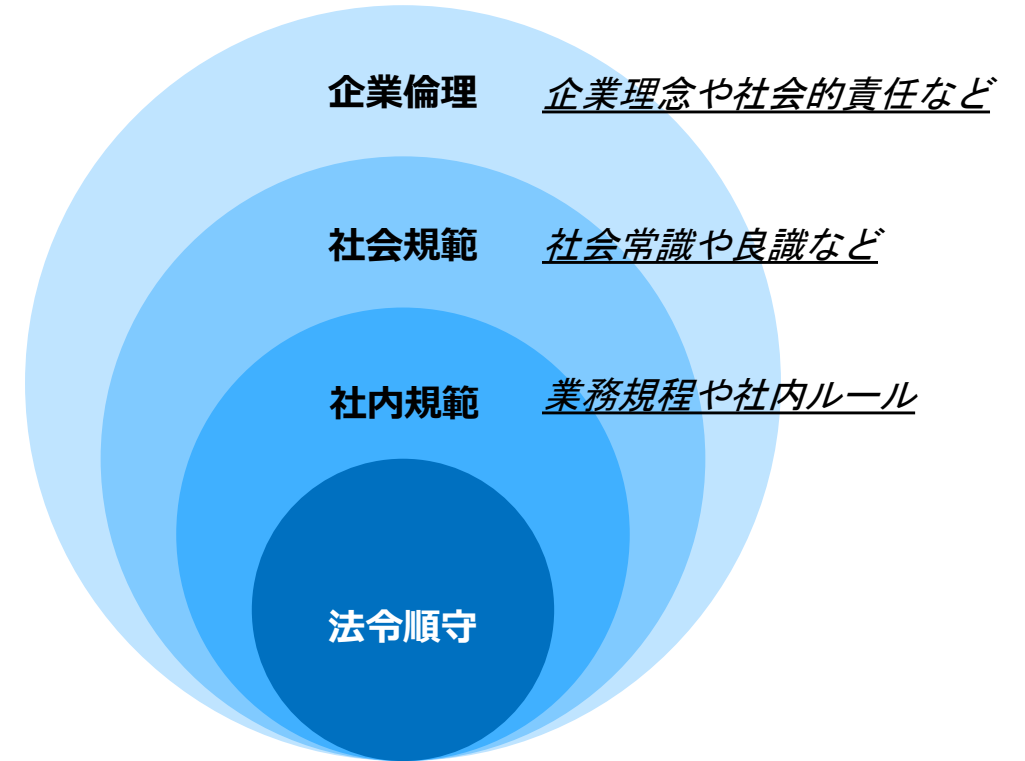
●コンプライアンス

コンプライアンス

- コンプライアンスとは、倫理観や公序良俗などの社会的な規範に従い、公正で公平に業務をおこなうことを意味しています。

協力会社でのコンプライアンス

- アウトソーシングした時、コンプライアンスに関するリスクがなくなったわけではありません。顕在化しにくくなる側面があります。



試験は広義コンプライアンス？

コンプライアンスの概念には広義と狭義が含まれます。
CISSPの試験においては広義の意味で問題ありません。



セキュリティの概念

セキュリティの概念

CIAトライアド

●CIAトライアド（機密性・完全性・可用性）

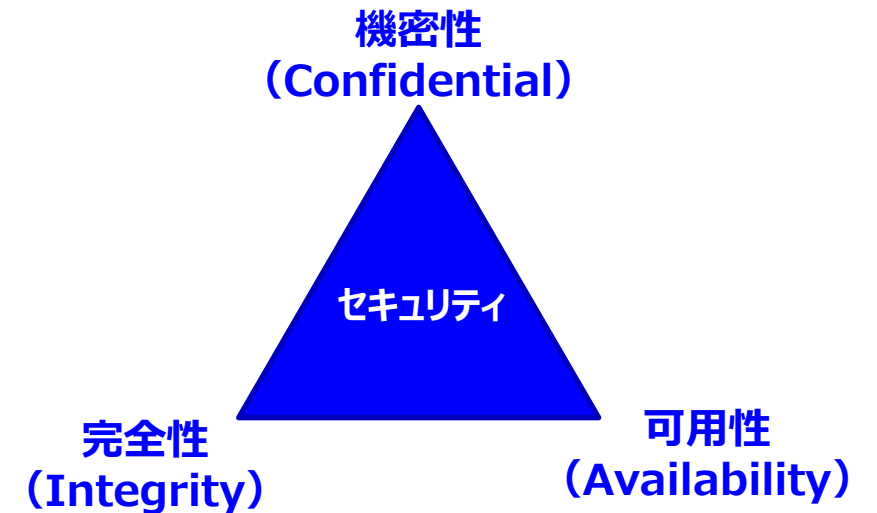
CIAトライアドとは、セキュリティ確保に必要な要素です。

- **機密性（Confidential）**とは、第3者に情報が漏洩・盗聴しない性質です。
- **完全性（Integrity）**とは、情報の改ざんや破壊が行われず完全かつ正確な情報である性質です。
- **可用性（Availability）**とは、サービス稼働の継続を示す性質です。

機密性、完全性、可用性のバランスを取ることが重要です。

●DAD（漏洩・変化・破壊）

CIAトライアドの反義語で漏洩（Disclosure）・変化（Alteration）・破壊（Denial）を示します。



CIAを満たしている＝セキュリティが確保されている

セキュリティの概念

CIAトライアド

●機密性（Confidential）

機密性（Confidential）とは、第3者に情報が漏洩・盗聴しない性質です。

機密性に関連する性質

- ・ 感受性とは、開示された場合に問題を引き起こす可能性がある度合いです。
- ・ 裁量とは、損害を最小限に抑えるために制御することができる決定の度合いです。
- ・ 重要度とは、ミッションクリティカルのレベルです。
- ・ プライバシーとは、個人を識別できる情報を秘密にすることです。
- ・ 独立とは、情報の混同を防ぐことです。

機密性を損なう脅威の例



社外の人に機密事項を話してしまった！



暗号鍵が計算され、
暗号通信が解読されてしまった！



普通の画像データと思ってたが、
電子データに機密情報が埋め込まれていた！

セキュリティの概念

CIAトライアド

● 完全性 (Integrity)

完全性 (Integrity) とは、情報の改ざんや破壊が行われず完全かつ正確な情報である性質です。

完全性に関連する性質

- 正確性とは、情報が正確であることです。
- 真実性とは、情報が事実に基づいていることです。
- 真正性とは、本人が行ったことを保証することです。
- 妥当性とは、事実上または論理的に健全であることです。
- 否認防止とは、記録されている情報が事実として否定することができないことです。
- 説明責任とは、監査ログに処理の記録をされていないといけないことです。
- 包括性とは、挙動を示すすべての必要な要素を含んでいることです。

完全性を損なう脅威の例



意図しないデータベース操作を実行されてしまった！



暗号文に不正な文字列を挿入されてしまった！

セキュリティの概念

CIAトライアド

● 可用性 (Availability)

可用性 (Availability) とは、サービス稼働の継続を示す性質です。

可用性に関連する性質

- アクセシビリティとは、広範囲の利用者を対象にリソースとやりとりできるという保証です。
- 適時性とは、合理的な時間枠内で収めるよう低遅延応答等を提供することです。
- ユーザビリティとは、サービスの利用者が使いやすい状態です。

可用性を損なう脅威の例



大量のリクエストを送付され、機器が壊れた！



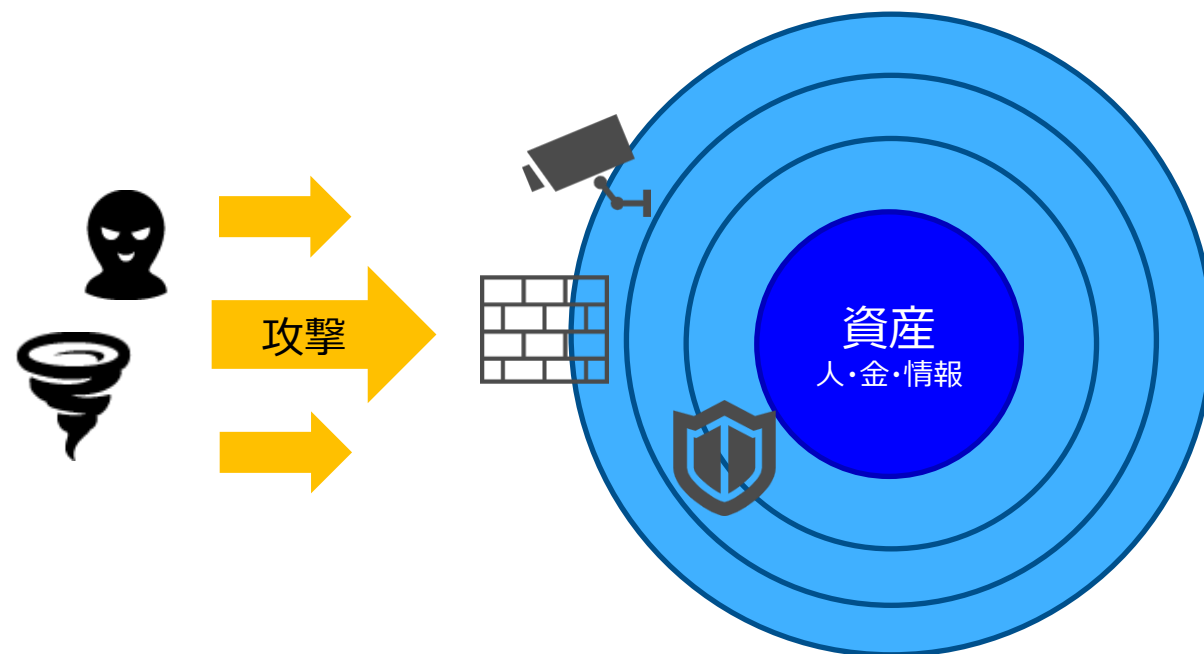
震災が起きたときにサーバーが止まってしまった！

セキュリティの概念

多層防御と曖昧さ

●多層防御とセーフガード

- **多層防御**とは、**セーフガード**（セキュリティ防御策）は、多層であるべきという考え方です。
- 特定の脆弱性のみに対応した高価な製品のように、一面のみに特化したセキュリティを講じることは得策ではありません。
- 例えば、頑丈なドアしていても監視カメラを設置すべきですし、ネットワークファイヤーウォールを設置していてもコンピュータエンドポイントでのウイルス対策ソフトをインストールするべきです。



セーフガードの多層にすることで抜け目なく保護する

セキュリティの概念

多層防御と曖昧さ

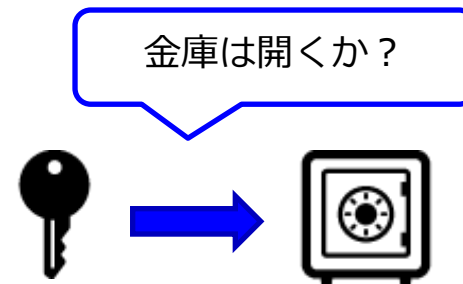
● 情報資産に対する保護メカニズム

抽象化/あいまいさ (obscurity)

- ・ 情報が存在していること自体をわからせないようにすることです。

隠蔽 (data hiding)

- ・ 情報が存在していることはわかって、詳細な情報に行きつかなくさせることです。
- ・ 知られたとしても漏洩を許さない概念は、ケルフホフスの原理など暗号化技術の基礎となる考え方になります。



隠蔽によるセキュリティ

鍵は複雑で暗証番号が必要で、構造を知られたとしても開けられない。



あいまいさによるセキュリティ

実際には簡単に開くが、これを知られなければ開けられないことはない。

セキュリティの概念

最小権限の原則・知る必要性

●主体 (subject) と対象 (object)

アクセス制御をモデル化するとき、アクセス主体とアクセス対象という関係性で整理します。

主体 (subject)

- 人間やコンピュータといった、データを操作する側を示す概念です。

対象 (object)

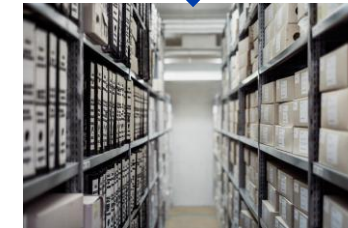
- データそのものやドキュメントなど、データを操作される側を示す概念です。

主体



アクセス
制御

対象



データにアクセスするもの、
アクセスされるに対してアクセス制御を行う

セキュリティの概念

最小権限の原則・知る必要性

● 最小権限の原則と知る必要性

最小権限の原則（Least Privilege）

- 権限は必要最低限であるべきというアクセス制御の基礎となる原則です。
- 最小特権の原則とは、どのようなユーザー、プログラム、サービスであっても、その機能を果たすために必要な最低限の権限のみを持つべきだという考え方です。

知る必要性（Need to Know）

- 知る必要性とは、機密性が高いと考えられる情報またはシステムへのアクセスに関して、アクセスを必要とする者に限られた期間だけ制限することです。

最小権限の原則

職権依存の アクセス権

職務や職位ベース
でアクセス権が定
義される。

あなたはデータベ
ース管理者なので、
ファイルアクセス
権限はありません。



知る必要性

タスク依存の アクセス権

タスクベースでアクセ
ス権が定義される。

本日の仕事では、
ファイルアクセス
は不要なのでアク
セスできません。



セキュリティの概念

真正性・否認防止

● 真正性 (authenticity)

真正性とは、十分に認証され、本人であることが確保されることです。

多要素認証などによって、改ざんされていなかったとしても、データを送った人が本人であることを担保しなければなりません。

● 否認防止 (non-repudiation)

否認防止とは、拒否することのできないず認めざるを得ないというフォレンジックの基礎となる原則のことです。

遡って訴求することができる特徴があります。認証は本人性の確認であり、認証されたという記録だけでは否認不可とはならず、現時点までデータが変更されていないことを担保する必要があります。

真正性を損なう脅威の例



2要素認証がなく本人に成りすましてサービスを利用できる！

否認防止を損なう脅威の例



ログが残っていない！
アカウント名を変えたら以前の操作履歴が残っていない！



セキュリティガバナンス

セキュリティガバナンス

セキュリティ機能と事業戦略の整合性

●ガバナンス

ガバナンス（CEO、CIO、CSO）

- 利害関係者のニーズを評価して、信頼を維持するための管理体制です。

マネジメント（セキュリティ専門家など）

- ガバナンスを基としたビジネス目標を達成するための管理です。

ガバナンス
(CEO、CIO、CSO)

マネジメント
(セキュリティ専門家)

取締役会

経営者

管理者

業務担当者

セキュリティガバナンス

組織プロセス

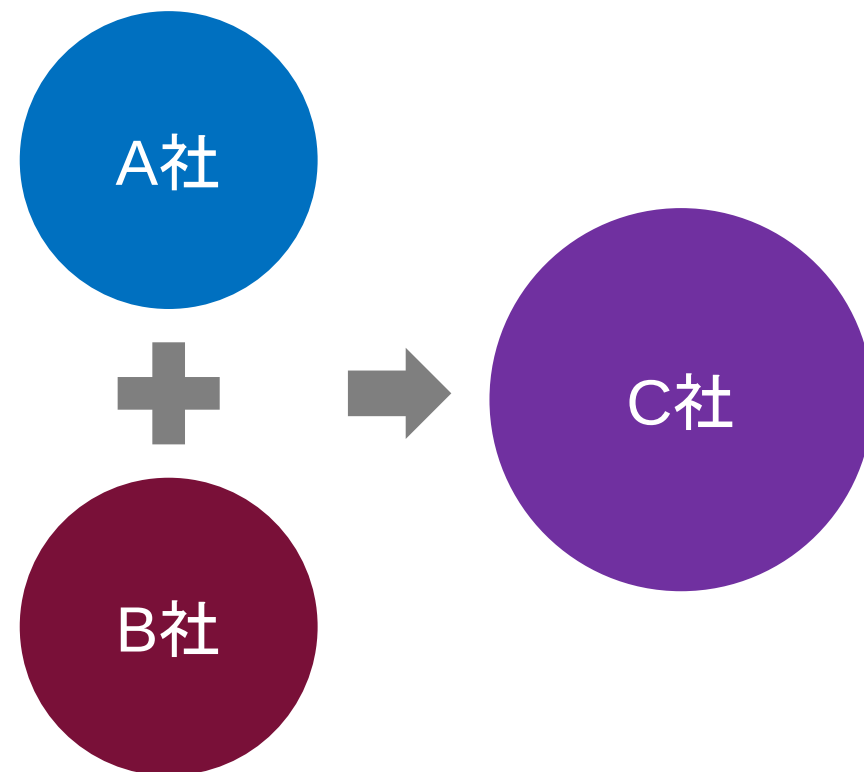
● ガバナンス委員会

ガバナンス委員会とは、組織が健全な運営を行うべく、自ら管理・統制する事項について審議し、報告及び提言を行います。

● 買収・合併による影響

買収・合併の際には、ガバナンスの統合する必要があります。

A社がB社を買収しても、B社の実態がA社のような働き方を吸収してくれるとは限りません。また、互いの良いところが統合されずに、脆弱性が浮き彫りになるケースもあります。



セキュリティガバナンス

組織の役割と責任

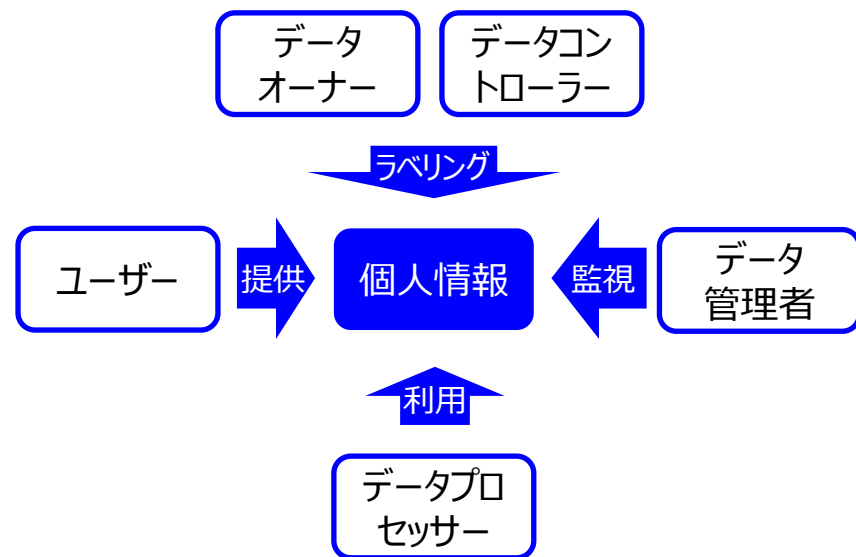
● 役職と責任

ビジネスオーナー・ミッションオーナー（上級管理職）

- ・ 組織における情報セキュリティの最高責任者です。
- ・ 情報セキュリティプログラムを作成し、適切な人員配置、資金提供、および組織の優先順位を確保します。彼らは、すべての組織資産が保護されることを保証する責任があります。

データオーナー／システムオーナー

- ・ システムオーナーは、現場におけるセキュリティの最終責任者です。セキュリティポリシーの承認者、および、リソースの確保やメンバー間の対立の仲裁なども役割もあります。
- ・ データオーナーは、コンピューターに含まれるデータを保護する責任があります。システムオーナーは、コンピューターのハードウェアとソフトウェアを保護する責任があります。
- ・ 特に各部署から個人情報を中心としたデータの取り扱いに関して依頼があるため、承認する役回りではありますが、決してデータそのものの所有者ではありません。
- ・ データオーナーは自組織におけるデータ保護の要件を決め、データ管理者がその具体的な実現方法を定義します。



データ保護のための体制

セキュリティガバナンス

セキュリティ管理フレームワーク

●ISO/IEC 27000シリーズ

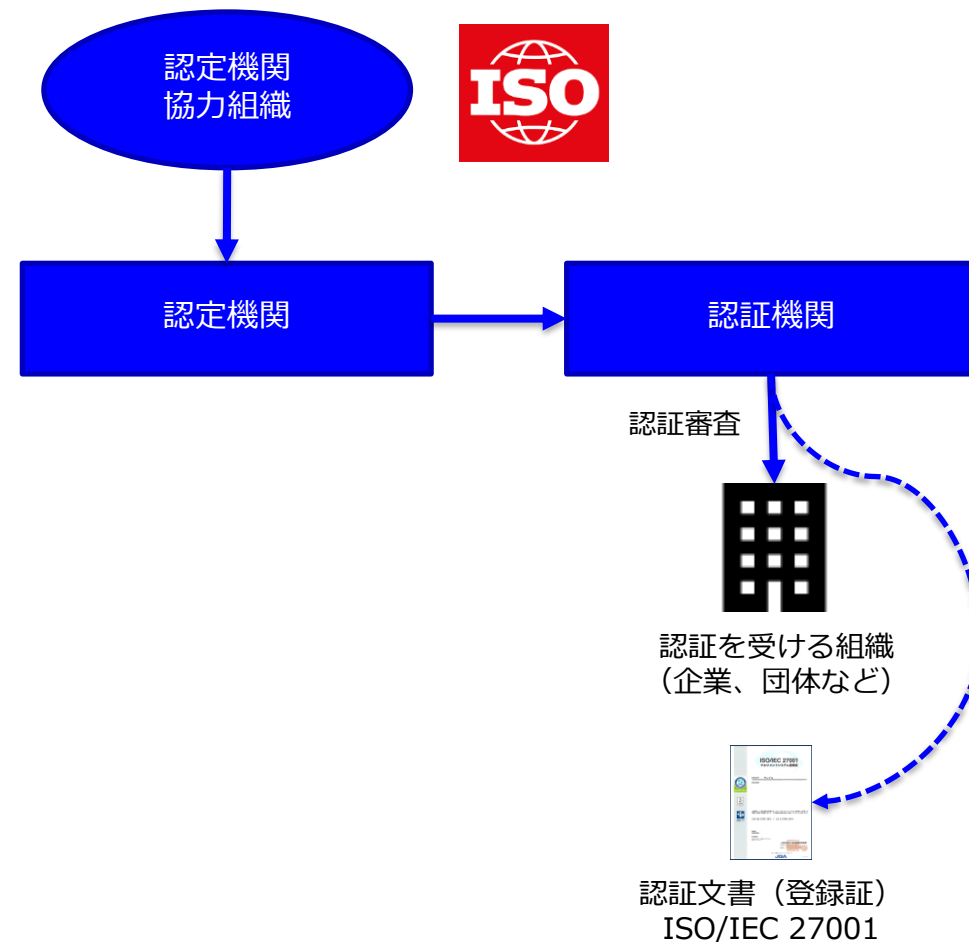
ISO（国際標準機構）とIEC（国際電気標準会議）が共同制作した適切な情報セキュリティマネジメント（ISMS）を提供するための規定です。

ISOは、世界中で同じ品質のものを提供するための国際的な基準を発行する機関です。

認定機関とは、審査を行う組織を認める機関です。認証機関とは、審査を行う機関です。

ISO/IEC 27000シリーズの主なトピック

- ISO/IEC 27001 ISMSに要求される事項
- ISO/IEC 27002 ISMSの実践のための決まり
- ISO/IEC 27004 ISMSの成功を定義づけ
- ISO/IEC 27005 リスクマネジメントを中心にしたISMSの考え方
- ISO/IEC 27799 PHI（個人健康情報）の扱いに関する規則



セキュリティガバナンス

セキュリティ管理フレームワーク

● リスクマネジメントフレームワーク

リスクマネジメントフレームワーク（Risk Management Framework）とは、組織や情報システムにおける情報セキュリティリスクの管理方法を示したものです。

Revision 1：連邦政府情報システムに対するリスクマネジメントフレームワーク適用ガイドーセキュリティライフサイクルによるアプローチ

- 米国連邦政府の情報システムを対象とします。
- システム開発や運用保守のプロセスにおけるセキュリティリスクの評価・対策・実装・監査を行うためのガイドラインです。

Revision 2：情報システムおよび組織のためのリスクマネジメントフレームワークーセキュリティとプライバシーのためのシステムライフサイクルアプローチ

- 対象が米国連邦政府の情報システムだけでなく、すべての組織を対象とします。
- プライバシーリスクも明示的に取り扱います。

セキュリティガバナンス

セキュリティ管理フレームワーク

● リスクマネジメントフレームワーク

ステップ1 リスクマネジメントの準備 (PREPARE)

- 組織のリスクマネジメント戦略を策定する。
- 組織全体に対するリスク評価を行い、別々のシステムに対しても共通可能な管理策を特定する。

ステップ2 情報システムの分類 (CATEGORIZE)

- システムに求められるセキュリティ分類を機密性、完全性、可用性の観点でそれぞれ高、中、低に決定する。

ステップ3 セキュリティ管理策の選択 (SELECT)

- セキュリティ管理策を、ベースラインの中から選択し、必要な場合はその内容を調整します。

ステップ4 セキュリティ管理策の実装 (IMPLEMENT)

- 対象システムのセキュリティ管理策を実装します。

ステップ5 セキュリティ管理策のアセスメント (ASSESS)

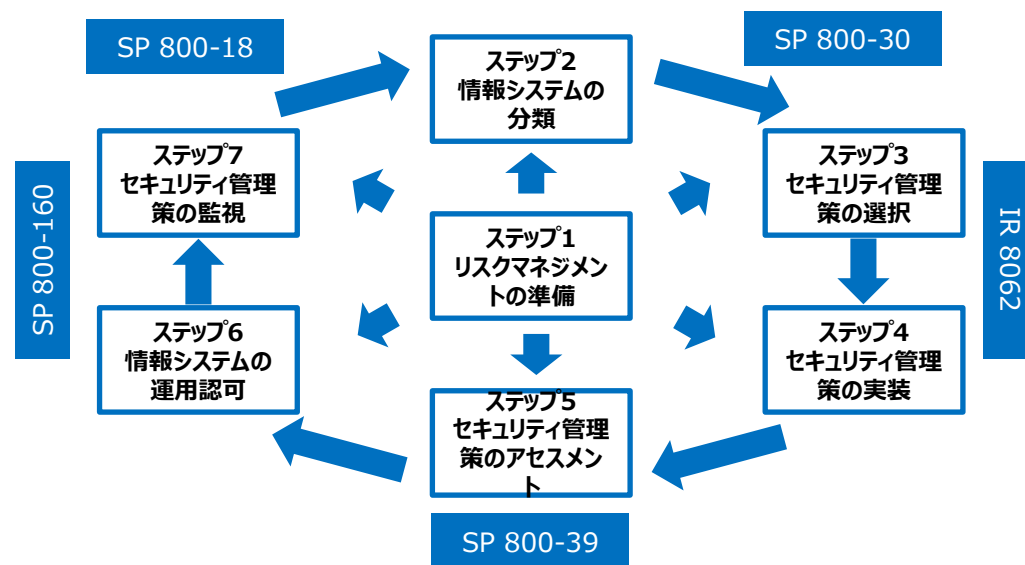
- 対象システムのセキュリティ管理策が、実際にセキュリティの要件を満たしているかを評価する。

ステップ6 情報システムの運用認可 (AUTHORIZE)

- 運用責任者に、対象システムの運用認可を申請し、リスクが受容可能であれば運用が認可されます。

ステップ7 セキュリティ管理策の監視 (MONITOR)

- 対象システムのセキュリティ管理策の有効性を継続的に評価します。
- 運用認可の申請と認可も継続的に行われます。また、対象システムを廃止する段階では、廃止に必要な作業を行います。



セキュリティガバナンス

セキュリティ管理フレームワーク

● リスクマネジメントの準備（PREPARE）の詳細

セキュリティとプライバシーのリスクを管理するためのコンテキストと優先順位を決定し、組織レベルおよびシステムレベルの観点から準備をするものです。

組織レベル

- ・ レベル1および2（組織およびミッション／ビジネスプロセス）では、組織レベルの準備を行う必要があり、特定システムに限定しません。
- ・ リスクアセスメント、リスクマネジメント、サプライチェーンリスクマネジメントなどを実施することになります。

システムレベル

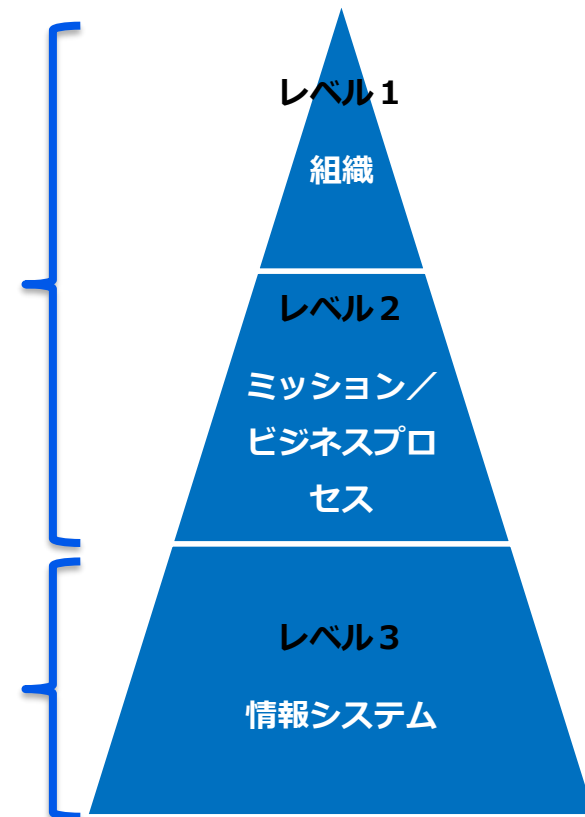
- ・ レベル3（情報システム）のリスクマネジメントは、システムレベルの準備を行う必要があり、特定のシステムのリスクを取り扱います。
- ・ 資産管理、リスクアセスメントなどを実施することになります。

組織レベル

組織全体のセキュリティとプライバシーのリスク評価・管理を行います。

システムレベル

対象となるシステム範囲を明確にし、セキュリティとプライバシーのリスク評価・管理を行います。



セキュリティガバナンス

セキュリティ管理フレームワーク

● COBIT

COBIT (Control Objectives for Information and related Technology)

- 米国の情報システムコントロール協会 (ISACA) とITガバナンス協会 (ITGI) が提唱し、企業のITガバナンスの成熟度を測るフレームワークが提供されています。
- COBITの目的とは、マネジメントとビジネスプロセスとともに情報技術のガバナンスモデル提供するものである。それは情報技術から価値を生み出し、理解し、情報技術に関するリスクを管理するものです。

COBIT成熟レベル		内容
0	存在しない	問題を認識できていない。
1	初期	問題は認識できているが、行き当たりばったりに解決している。
2	反復可能	マニュアル作成しているが、マニュアルに沿ったトレーニングを実施していない。
3	定義済み	トレーニングを実施しているが、プロセス改善ができていない。
4	管理可能	プロセス改善を実施しているが、まだ改善できる余地がある。
5	最適化	ベストプラクティスと呼べるほど完成されている。

項目	内容
計画と組織	IT戦略およびビジネス目的を達成させるうえでIT部門が最も貢献できるプロセスが含まれています。
調達と導入	IT戦略を適切に実行に移すには、ITソリューションを特定、開発、または取得するのはもちろん、ビジネスプロセスの枠内で実行し、ビジネスプロセスに統合することが必要となります。
デリバリーとサポート	セキュリティや継続性を司るオペレーション、教育・訓練といったさまざまなITサービスの提供に関する領域です。
モニタリングと評価	全てのITプロセスは、継続して定期評価の対象としてプロセスの品質及び統制要件に関する準拠の度合いを監視しなければなりません。

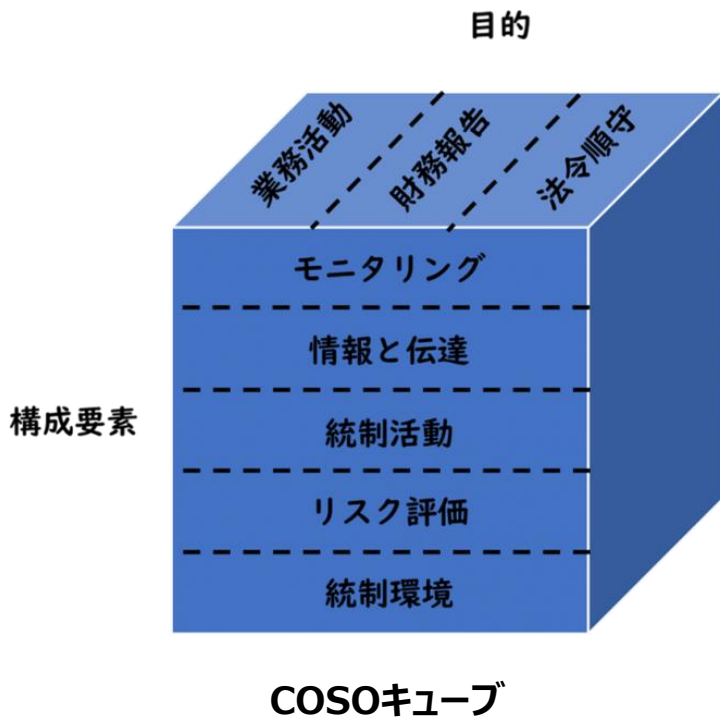
セキュリティガバナンス

セキュリティ管理フレームワーク

●トレッドウェイ委員会支援組織委員会

トレッドウェイ委員会支援組織委員会（Committee of Sponsoring Organizations of the Treadway Commission）

- 組織統治、ビジネス倫理、内部統制、ビジネスリスクマネジメント、不正行為および財務報告などについて、経営幹部や政府機関に対して指導することを目的として設立されました。
- もしくは、粉飾決算につながらないように業務の適正化を計るフレームワークを提示している委員会です。
- COSOキューブでは、業務活動、財務報告、法令順守のそれぞれの目的をモニタリング、情報と伝達、統制活動、リスク評価、統制環境の5つの観点で整理することを示しています。



セキュリティガバナンス

セキュリティ管理フレームワーク

● PCI DSS

PCI DSS (Payment Card Industry Data Security Standard)

- 電子決済（主にクレジットカード利用）する際に、個人情報流出を避けるためのフレームワークです。
- 2004年に国際カードブランドのAmerican Express、Discover、JCB、MasterCard、VISAの5社によって策定・共同設立した組織であるPCI SSC（PCI Security Standards Council）によって運営／管理されています。

PCI DSSの要件

- 安全なネットワークとシステムの構築と維持
- カード会員データの保護
- 脆弱性管理プログラムの整備
- 強力なアクセス制御手法の導入
- ネットワークの定期的な監視およびテスト
- 情報セキュリティポリシーの整備



自己問診

自己評価問診票の設問に回答することにより、文面上でPCI DSS基準をどれだけ満たしているか確認することができます。



リモートによる脆弱性スキャン

ASV（Approved Scanning Vendor）が遠隔地からの操作することによりインターネットに接続されているネットワーク機器やサーバー機器の脆弱性をチェックできます。



訪問審査

QSA（Qualified Security Assessor）が各事業者にも実地訪問し、セキュリティ対策、運用及び情報の取り扱い状況に関するインタビューや検査を実施します。

セキュリティガバナンス

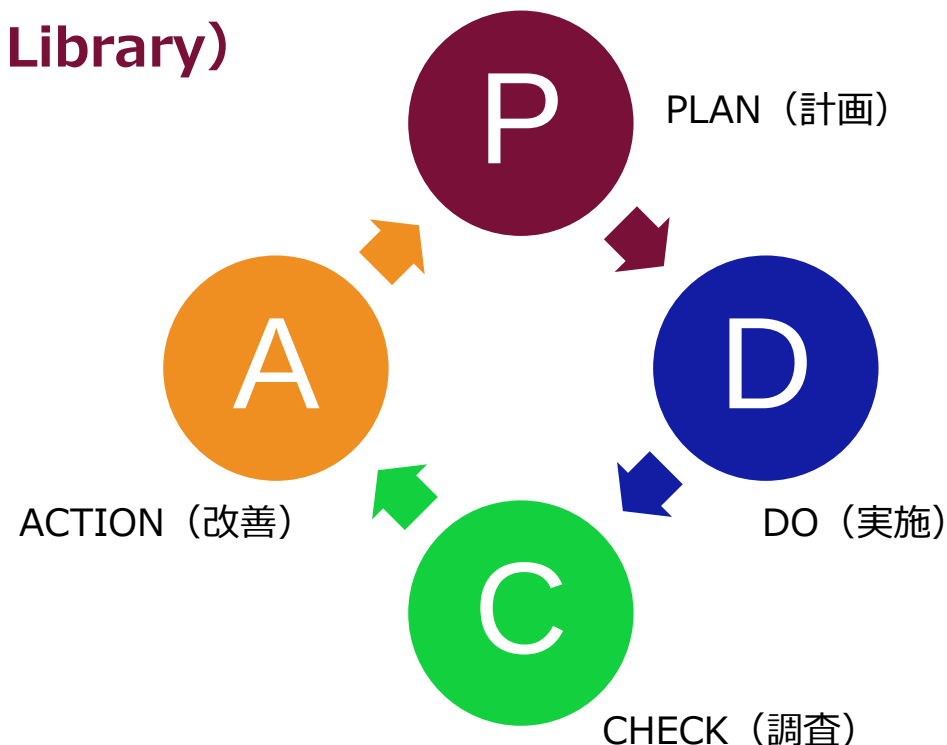
セキュリティ管理フレームワーク

● ITIL (Information Technology Infrastructure Library)

- ITサービスマネジメントにおけるベストプラクティス（成功事例）をまとめた書籍群です。
- ITサービス管理の考え方を整理したもので、そのドキュメントの構成自体が、ITサービス管理のためのテンプレートになっています。
- ほかのフレームワークとの違いは“実践されている”点にあります。体系的にまとめられていたとしても現実での複雑性に踊らされることがあります。自組織のフレームワークをより強化することにも貢献します。

ITILの構成要素

- サービス戦略
- サービスデザイン
- サービス移行
- サービスオペレーション
- 継続的なサービス改善



PDCAサイクルは、米国の統計学者ウィリアム・エドワーズ・デミングが1950年代に提唱した、マネジメント品質を改善するためのフレームワークです。

セキュリティガバナンス

デューケア・デューディリジェンス

●内部統制

デューケア (Due Care)

- 従業員が組織から敷かれているルールに十分な努力をもって従うこと。
- セキュリティや倫理によって守られるべきという行動であり、「前もって動く」という行動も含まれる場合があります。

デューディリジェンス (Due Diligence)

- デューケア (Due Care) を守るための正当な仕組みや制度です。
- デューケアの前に調査を行い、行動が効果的であることを確認する行為も含まれます。

デューケア (Due Care)

決定事項を
実行

決定事項が決められた以降の適切な行動。
PRUDENT MAN RULE
とも呼ばれる。

適切なルールに
まっとうに従う
姿勢が大事な
る。



デューディリジェンス (Due Diligence)

決定事項を
整理

研究・計画・評価
し、会社のルール
として適切な枠組
みを整理する。

適切なルールが
なければ従いよ
うがない。





情報セキュリティ関連の規制

情報セキュリティ関連の規制

サイバー犯罪とデータ侵害

● 攻撃者の呼び方

ハッカー

- ・ コンピューターに詳しい人です。
- ・ コンピューターの攻撃する人という意味で用いられることがありますが、本来はそのような意味はありません。

クラッカー

- ・ コンピューターやシステムの脆弱性を認識し攻撃を行う人です。
- ・ 攻撃目的は、快樂、政治的（ハクティビスト）、金銭的、諜報などが挙げられる。

スクリプトキディ

- ・ コンピューターの専門知識も持たずに、脆弱性ツールなどを使ってサイバー攻撃する人です。
- ・ Webに出回っている攻撃ツールや脆弱性診断ツールなどの利用を許可していないサービスに勝手に利用することで攻撃を成立させます。



アノニマス

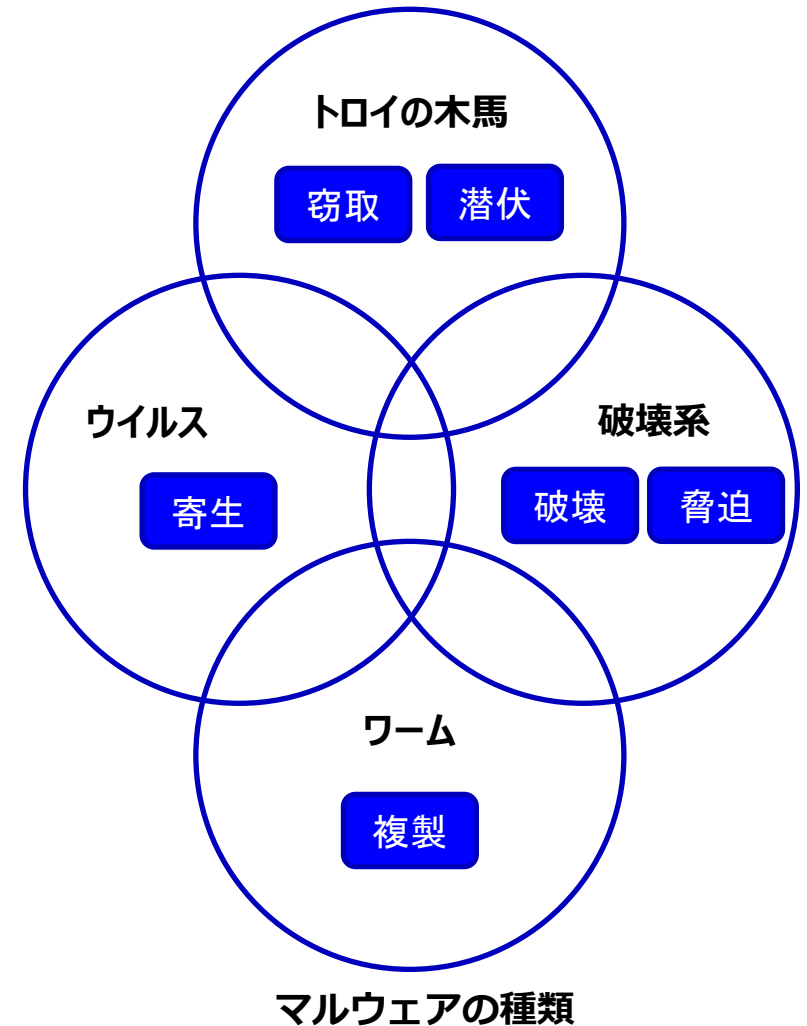
アノニマスは、国際的なハッカーのネットワークであり、ハクティビストです。アラブの春として知られる2010年から2011年にかけてアラブ社会での反体制活動では、政府に対してサイバー攻撃をしかけていたことが確認されています。アノニマスという組織があるわけではなく、反体制精神をもつ個人がデジタル技術を使った攻撃を行い、表明する際に「アノニマス」という名乗るとするのが通説です。

情報セキュリティ関連の規制

サイバー犯罪とデータ侵害

●マルウェア

- トロイの木馬とは、伝染するとき一見無害そうに見えるマルウェアです。密かに潜伏して、情報を収集します。例：RAT、キーロガー、ダウンローダー、バックドア、ボット、ルートキットなど。
- ウイルスとは、他のプログラムに寄生するタイプのマルウェアです。例：マクロ感染型（Excelなどのアプリの裏処理プログラムに従属）、ブートセクタ感染型（パソコン起動プログラムに従属）、ファイル感染型（実行ファイルに従属）。
- ワームとは、ユーザーの操作なしに伝染するマルウェアです。自分自身のコピーを勝手に生成し、感染を拡大します。
- 破壊系のマルウェアとは、ランサムウェアに代表される破壊系のマルウェアです。これは、情報端末の操作をロックすることで更なる要求を行うマルウェアです。例：ランサムウェア、ワイパー、スクリーンロッカー、スケアウェア、ワンクリックウェア。
- 潜在的にマルウェアと解釈されるものも存在します。明確にマルウェアとは言えないものの、環境によっては侵害に至るケースがあるプログラムです。スパイウェアのように秋のあるものもあれば、マーケティング目的でユーザー同意を得ている場合もあります。例：アドウェア、スパイウェア、脆弱性診断ツール。



情報セキュリティ関連の規制

ライセンスと知的財産

● 知的財産の種類

商標 (Trademark)

- ブランド力をつけるものロゴ・社名のことです。
- ロゴの右上に“R”が入っているものは、ロゴが権利 (Right) に保護されていることを示します。

特許 (Patent)

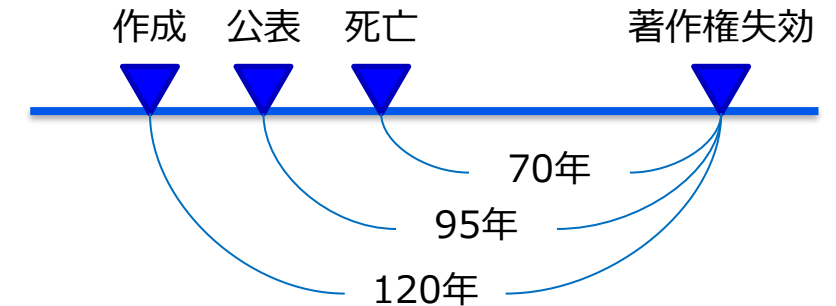
- 薬など発明物に対して、技術の使用を独占する権利のことです。
- 特許期間 (特許権満了日) は原則として「出願日」から20年です。

著作権 (Copyright)

- 音楽や本など、創造し考えて作ったものへの権利のことです。
- 消尽 (First Sale) とは、著作物の権利を譲渡・売却した場合には、権利を失うこと。
- アメリカの著作権法 (Copyright Act of 1976) では、死亡してから70年、公表されてから95年、作られてから120年で著作権が失効します。

PIEDPIN®

商標登録されたロゴや名前。原則、右上にRのマークがある。



情報セキュリティ関連の規制

ライセンスと知的財産

● 知的財産の種類 ライセンス

- スマホアプリケーションなど、利用権利のことです。
- 一般ユーザへのライセンスをエンドユーザライセンスアグリーメント（EULAs）といいます。

営業秘密（trade secret）

- 顧客情報、製品の技術・製造方法など事業活動として有益であり、機密としている情報のことです。
- 単なる推測など、合理的に確かめていない情報は営業秘密に含まれません。

コカ・コーラはただの砂糖水？

コカ・コーラの原液のレシピは、社内で厳重に管理されています。その上、限られた人しか知っていないとされています。そして、事業活動として全世界に売られている飲料です。したがって、単なる砂糖水と思う方がいるかもしれませんが、立派な営業秘密になるわけです。



情報セキュリティ関連の規制

ライセンスと知的財産

● デジタルミレニアム著作権法 (Digital Millennium Copyright Act)

- デジタルコンテンツの著作権に関する法律です。自分の著作物などが他のサイトで勝手に利用されていた場合などに権利を通知することができます。
- 通告を受け取ったサイトの運営者は対象のコンテンツを迅速に削除します。削除した場合、著作権侵害の責任は免除されることになります。

電子透かし (デジタルウォーターマーク)

- 画像や動画などに識別子情報を埋め込むことです。
- 発売前の限定品のデザインの画像に“SAMPLE”という文字が覆っていることあると思います。これは、元の画像を利用させないということと、仮に復元された場合に不正に復元する意思があるということを示すためのものでもあります。
- “SAMPLE”という文字を浮かび上がらせずに、画像自体に著作権の情報が見えない形で埋め込まれていることがあります。



SAMPLEや企業のロゴを透かして、画像や動画に張り付けることで、不正な利用を抑止する

情報セキュリティ関連の規制

ライセンスと知的財産

● 連邦経済スパイ法 (Economic Espionage Act of 1996)

- 営業秘密 (trade secret) を漏洩した場合に罰する刑事法です。
- 産業スパイだけでなく、心神喪失の抗弁、米国少年少女クラブに関する事項、調査報告書の要件、暗号化またはスクランブル技術に関する米国量刑委員会の報告書、その他技術的な細かい修正など幅広い問題を扱った議会法です。
- 連邦経済スパイ法は刑事法であるが、類似法律として民間レベルのトレードシークレット法も存在します。

法の構造

項番	名前
I	営業秘密の保護
II	1996 年国家情報基盤保護法
III	心神喪失を理由に無罪とされた者の移送
IV	少年少女クラブの設立
V	犯罪行為を促進するための特定の技術の使用
VI	技術的および小修正

情報セキュリティ関連の規制

輸出入規制

● 輸出管理規制

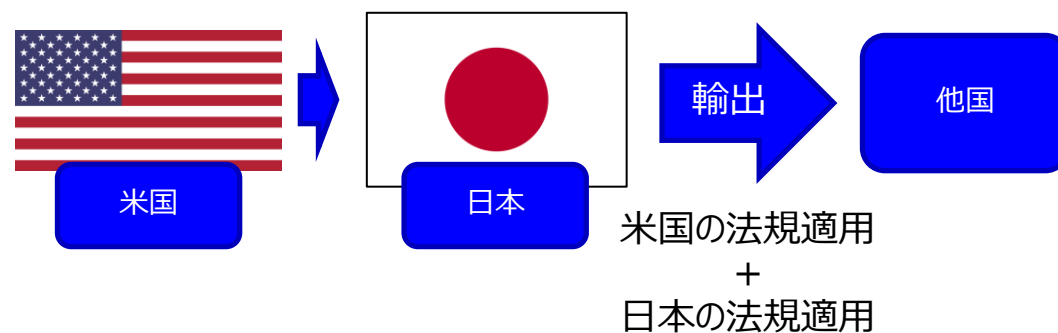
米国の輸出管理法規は、主権や管理権の及ばない他国との取引にも適用されます。（域外適用）

例えば、米国が原産国のものを日本から輸出する場合には日本への外為法を守るとともに、これに加えて米国の再輸出規制を守る必要があります。

もしも、違反した場合には米国の法令違反となり米国から行政制裁が下る可能性があります。

デュアル・ユース

- 輸出品は、軍用としても民生用としても両方使えるデュアル・ユースという場合があります。
- そのため、輸出した製品が何を目的に輸入され、実質的に何に使われたのかを追跡する側面を持ちます。



情報セキュリティ関連の規制

輸出入規制

● 対共産圏輸出統制委員会

ココム（COCOM、Coordinating Committee for Multilateral Export Controls）

- ワッセナーアレンジメントの前身として、第二次世界大戦での冷戦時代にアメリカを代表とする資本主義国（北大西洋条約機構、NATO）の軍事技術がソ連を代表とする共産主義国（ワルシャワ条約機構、WTO）への漏洩しないようにするための委員会のことです。
- 対共産圏輸出統制委員会の目的としては、軍事力や技術力の格差を維持することです。
- アイルランドを除く北大西洋条約機構（NATO）加盟国と日本・オーストラリアの計17か国が加入していました。1994年にソ連崩壊により、対共産圏輸出統制委員会も解体されます。

情報セキュリティ関連の規制

越境データフロー

●EUのプライバシー法

データ保護指令（DPD、EU Data Protection Directive）

- EU市民データの保護を目的にプライバシー情報の管理についての指令のことです。
- 組織は、データがどのように収集および使用されるかを個人に通知する必要があり、サードパーティとのデータ共有をオプトアウトできるようにする必要があります。また、データの受領国が適切なプライバシー保護を持っていると認められない限り、EU域内からの送信はない。
- 加盟国は、独立した国家としての立法権、司法権、行政権を持っています。GDPRは加盟国一律に適用される規則になります。加盟国の法律は国内法という扱いになり刑罰の可能性もありますが、GDPRは制裁金という扱いになります。

データ保護指令 （1995年）



要請



EU加盟国が国内法制化

GDPR 一般データ保護規則



直接適用



情報セキュリティ関連の規制

越境データフロー

●EUのプライバシー法

一般データ保護規則（GDPR、EU General Data Protection Regulation）

- 個人データの保護に対する権利という基本的人権の保護を目的とした法律のことです。
- EU所在者の個人データをやり取りする、EU域内に拠点がある、EUのデータ主体に対する物品やサービスの提供を行う、行動を監視する場合には対象となります。

データ主体の保護

- アクセス権とは、個人が自分のデータにアクセスできるようにすることです。
- 消去権・忘れられる権利とは、企業が必要なくなったときに個人情報削除を要求する権利です。表現の自由との兼ね合いもあるため常に認められるわけではありません。
- データポータビリティの権利とは、個人データを取得している管理者を別の管理者に送信させる権利です。



- 氏名
- 識別番号
- 所在地データ
- メールアドレス
- オンライン識別子（IPアドレス、クッキー）
- クレジットカード情報
- パスポート情報
- 身体的、生理学的、遺伝子的、精神的、経済的、文化的、社会的固有性に関する要因

個人データ（GDPR）の例

情報セキュリティ関連の規制

越境データフロー

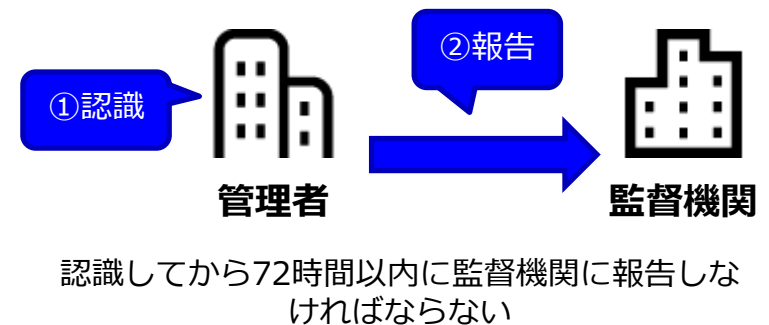
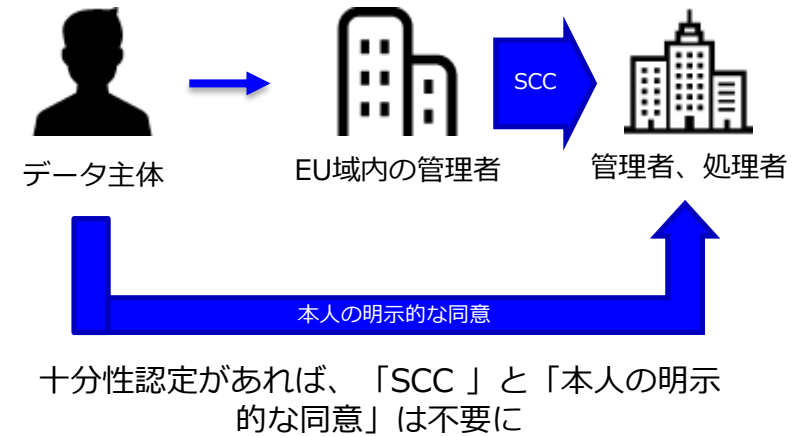
●EUのプライバシー法

十分性認定

- GDPRは、米国や日本といった地域外の諸外国に対して厳しい規制をかけています。EUから見れば、諸外国である日本も基本的にはデータ保護に関して十分な体制があるとは見なされないわけです。（2019年1月23日に日本も十分性認定を受けています）
- 十分性認定を受けていない場合には、EU域内とEU域外の組織間で標準データ保護条項であるSCC（SDPC）や本人の明示的な同意を得ておく必要があります。

72時間ルール

- データの侵害が発生した場合、データを管理している組織は個人データ侵害を認識してから72時間以内に管轄の監督機関に、当該個人データ侵害を通知しなければなりません。72時間を超えた場合、遅延に対する理由が必要になります。



情報セキュリティ関連の規制

プライバシー

●プライバシー情報とは

プライバシー情報

- プライバシーは個人情報の機密性を保護する総称です。
- 社会保険証番号などの個人識別番号（PII、Personally Identifiable Information）、給料などの財産情報、学歴などの教育情報、体重身長などの身体情報も保護される対象になります。

知らず知らずの個人情報

（※2022年4月施行改正個人情報保護法の解釈です。）氏名は、本人と同姓同名の人が存在する可能性があります。しかし、氏名のみであっても、社会通念上、特定の個人を識別することができるものと考えられますので、個人情報に該当すると考えられます。

メールアドレスはメールアドレスの文字列が特定の個人を識別することができる場合（例：kojin.ichiro@example.com）は、それ自体が単独で個人情報に該当します。



https://www.ppc.go.jp/all_faq_index/faq1-q1-4/#:-:text=%E3%83%A1%E3%83%BC%E3%83%AB%E3%82%A2%E3%83%89%E3%83%AC%E3%82%B9%E3%81%A0%E3%81%91%E3%81%A7%E3%82%82%E5%80%8B%E4%BA%BA%E6%83%85%E5%A0%B1%E3%81%AB%E8%A9%B2%E5%BD%93%E3%81%97%E3%81%BE%E3%81%99%E3%81%8B%E3%80%82,-%EF%BC%A1%EF%BC%91%EF%BC%8D%EF%BC%94&text=%E3%83%A1%E3%83%BC%E3%83%AB%E3%82%A2%E3%83%89%E3%83%AC%E3%82%B9%E3%81%AE%E3%83%A6%E3%83%BC%E3%82%B6%E3%83%BC%E5%90%8D,%E6%83%85%E5%A0%B1%E3%81%AB%E8%A9%B2%E5%BD%93%E3%81%97%E3%81%BE%E3%81%99%E3%80%82

情報セキュリティ関連の規制

プライバシー

●健康情報

医療保険の携行性と責任に関する法律（HIPAA、Health Insurance Portability and Accountability Act）

- 電子化した医療情報に関するプライバシー保護・セキュリティ確保について定めた法律です。暗号化、アクセス制御、暗号鍵の管理、リスク管理、PHI情報の監査と監視に具体的に対応するように求めています。
- 個人の健康状況や支払い状況などの個人を特定できる保護対象保健情報（PHI、Protected Health Information）を保護する目的です。特に個人に対する医療情報は、電子個人医療情報（ePHI）とも呼ばれます。
- PHIデータの保有者が、データの管理に関わる業務を外部に委託する場合は、ビジネスアソシエート契約を結ぶ必要があります。

経済的及び臨床的健全性のための医療情報技術に関する法律

（HITECH、Health Information Technology for Economic and Clinical Health Act）

- 医療機関が、HIPAAが定めるプライバシー規則、セキュリティ規則に準拠しているか監査します。

HIPAAとHITECHの違い

HIPAAとHITECHについて、「どちらも医療情報を適切に管理することを義務付けている」、「HITECHはプライバシー、HIPAAはセキュリティ」ことを覚えておけば、おおよそ試験対策としては十分と思いますが、念のため違いを説明しておきます。

HITECH以前は、患者は自分のePHIが誰に開示されたかを知ることができませんでした（許可されている場合も、許可されていない場合もあります）。2011年、米国保健社会福祉省はHITECHの要求する規則を発表し、患者が開示内容の報告を要求できるようになりました。これらの報告書は、誰がどのような権限で自分のePHIにアクセスし、閲覧したかを患者さんに説明するものになっています。

(<https://www.hipaajournal.com/hipaa-and-hitech/>)

情報セキュリティ関連の規制

プライバシー

● 児童オンラインプライバシー保護法 (US Children's Online Privacy Protection Act)

- 米国外の子どもを含む13歳未満に関する個人情報のオンライン収集を行っている個人や団体に適用されます。
- そのサービスからデータを受け取る全てのものを特定して明記した明確なプライバシーポリシーを掲載しなければなりません。
- 子どもからデータを収集する前に保護者から同意を得なければなりません。
- 保護者に収集した情報を閲覧してもらい、その利用に異議を申し立て、またその情報を第3者に利用させなくてもサービスを利用できるようにしなければなりません。
- 子どもに関するデータの収集量は限定しなければなりません。
- データの保持期間を限定し、合理的なセキュリティを保たなければなりません。。



情報セキュリティ関連の規制

法律・規制の要件

● 注意点

法律には専門知識が必要です。実践される際には、専門家へのご相談をお勧めいたします。

● 主義

制定法主義 (Civil Law)

- 法律として記されている内容を軸にし、文章の解釈を論理的に示します。日本でこの主義が多い傾向があります。

判例法主義 (Common Law)

- 過去にあった似たような事件の判決を軸にし、過去での判決から一貫性を得るものです。米国でこの主義が多い傾向があります。

宗教法 (Religious Law)

- 各地域で発達した宗教の習わしに応じて変わります。

● 法律の種類

刑法 (Criminal Law)

- 社会の秩序を保つために罰金を設けるなどの抑止をするための法律です。
- 検察官は、合理的な疑いを超えて (beyond a reasonable doubt) 犯罪事実を立証しなければなりません。

民法 (Civil Law)

- 被害を被った個人・集団、組織を救済するための法律のことです。
- 多くの場合、救済は経済的な方法によって行われます。

行政法 (Administrative Law)

- 政府、政府機関に対する法律のことです。
- 組織やシステムに対する規律を整備する目的があります。

情報セキュリティ関連の規制

法律・規制の要件

● 上場企業会計改革および投資家保護法

Public Company Accounting Reform and Investor Protection Act

- 上場企業に対して、対象の企業から独立している取締役によって構成される監査委員会の設置を義務づけています。加えて、匿名の告発を処理することも求められます。最高経営責任者（CEO）や最高財務責任者（CFO）は財務諸表の内容に責任をもち、不適切な修正に対してボーナス返還が行われ、故意であった場合には最長20年の禁錮刑、500万ドル以下の罰金を科されます。

● グラム・リーチ・ブライリー法

Gramm-Leach-Bliley Act, Financial Services Modernization Act

- グラス・スティーガル法の一部を無効にし、商業銀行、投資銀行、証券会社、保険会社での統合・合併が許可しました。
- 銀行の役員、取締役または従業員、証券会社役員、責任者または従業員によるサービスに関する利害対立禁止令も廃止しています。

シティグループの救済？

1998年に、シティコープ（商業銀行持株会社）はシティグループ（クレジットカードでお馴染み）を形成させるために保険会社のトラベラーズ・グループと合併した。そしてシティバンク、スミス・バーニー、プライメリカとトラベラーズを含んだブランドの下で銀行、証券、保険業務を統合した。兼業が禁止されている時点で統合が行われ、その後グラム・リーチ・ブライリー法が制定された。この法律は、これらの合併を合法化するために制定されたものとしての解釈もある。

情報セキュリティ関連の規制

法律・規制の要件

● 米国愛国者法

USA PATRIOT Act, Uniting and Strengthening America by Providing Appropriate Tools Required to Intercept and Obstruct Terrorism Act of 2001

2001の同時自爆テロを背景に制定され、以下の3つのコンセプトを掲げた。

- 国内および国際電話に対する法執行機関の監視の拡大
- 省庁間のコミュニケーションの緩和
- テロ犯罪に対する罰則の強化とテロ容疑にかける活動の拡大

● 連邦情報セキュリティマネジメント法

Federal Information Security Management Act of 2002

- 情報セキュリティは投資対効果のある活動であり、適正化が必要であるため予算を確保し組織も整備する。連邦政府関連の組織は毎年、行政管理予算局（OMB）にセキュリティ報告書を送る。
- 連邦政府機関、国立標準技術研究所（NIST）、行政管理予算局（OMB）から構成される。

エドワード・スノーデンの暴露

2015年6月2日、オバマ大統領はUSA PATRIOT法に代わってUSA FREEDOM（Uniting and Strengthening America by Fulfilling Rights and Ensuring Effective Discipline Over Monitoring）法に署名し、政府のデータ収集の権限を縮小させた。米国自由法では、FISA裁判所に公的な要請を提出した場合に、政府がデータにアクセスできると規定されていた。この改正は、2013年にエドワード・スノーデンが政府が電話やインターネットの記録を大量に収集していることを暴露したことが影響しているとされる。

情報セキュリティ関連の規制

法律・規制の要件

●コンピュータ詐欺と濫用に関する法律

CFAA (US Computer Fraud and Abuse Act)

- 政府や金融機関などの保護されたコンピューターに対して、意図的な損害を禁止する法律のこと。
- “意図的な”という解釈がコンピュータの世界で非常に難しいことが議論されてきました。

●法執行のための通信援助法

CALEA (US Communications Assistance for Law Enforcement Act)

- 電気通信事業者および電気通信機器の製造業者に、機器、設備、およびサービスを変更および設計することを要求することにより、法執行機関が合法的に通信を傍受することを強化する法律です。

CFAAを学ぶための映画「WarGames」

「WarGames」は、1983年のアメリカの冷戦 SF テクノスリラー映画。ソビエト連邦に対する核戦争を予測して実行するようにプログラムされた米軍のスーパーコンピューターに無意識のうちにアクセスする若いハッカー、デビッド・ライトマン（ロドリック）を追っています。



調査

調査

調査の種類

● 法的証拠

物的証拠 (Real Evidence)

- 物体として存在する証拠のことです。
- ナイフやDVDや契約書などです。純粋なデータは含まれないケースがあります。

直接証拠 (Direct Evidence)

- 事件の事実を示す直接的に説明可能な証拠のことです。
- 実際に見た人の証言、本人の自白などです。

情況証拠 (Circumstantial Evidence)

- 事件の事実を推測できる証拠のことです。
- 何が起きたかを示すものではないけれども、何かが起きたことがわかるような指紋やアリバイのための証言などです。

補強証拠 (Corroborative Evidence)

- 他の証拠の事実を証明するための別の証拠のことです。
- 自白は無理に言わせることもできるので、それだけでは証拠にならないことがある。そこに犯人がいたという、補強する証拠が必要になってきます。

伝聞証拠 (Hearsay)

- 体感したことを供述することです。
- 体験談などが上げられます。

二次的証拠 (Secondary Evidence)

- オリジナルから複製されたものです。
- 契約書のコピーなどが上げられます。

調査

調査の種類

●合衆国修正第4条（Amendment 4）

令状なく捜査・押収することは許されず、令状は宣誓・確約を基に相当な理由をもって発行され、捜査・押収対象も特定していなければなりません。

●証拠の収集

おとり捜査（犯意誘発型、entrapment）

- ・ 機密情報を自ら公開するなど、違反性のある行動の意図がないにもかかわらず犯罪をさせる行為のことです。
- ・ 違法、非倫理的とされています。

誘惑（enticement）

- ・ ハニーポットなど、既に違反性のある行動に意図があり、決定的な証拠を得るために状況を作る行為のことです。
- ・ 合法、倫理的とされています。

「To Catch a Predator」の是非

To Catch a Predatorは、ニュース雑誌番組『Dateline NBC』におけるアメリカのリアリティ番組です。未成年者になりすました番組スタッフと犯罪行為をしようとした大人を実際に逮捕してしまう内容です。

このシリーズは2004年11月に初放送されました。法執行機関やその他の当局が関与し、捕らえられたほとんどの人物を逮捕するに至りました。

そんな中、テキサス州ロックウォール郡の地方検事補ルイス・コンラッドは、13歳の少年を装った番組スタッフと写真を交換しているところを見つかり、警察とNBCの撮影班が自宅に入ってきたところで拳銃自殺しました。

調査

調査の種類

● 証拠保全（Chain of Custody）

証拠能力を保つための活動のこと。証拠を手に入れた時点から、いつ・どこで・誰が・何をしたものなのかの順番に書き残しておくなど、証拠能力を保持します。

● 証拠能力

伝聞証拠禁止の原則（Hearsay Rule）

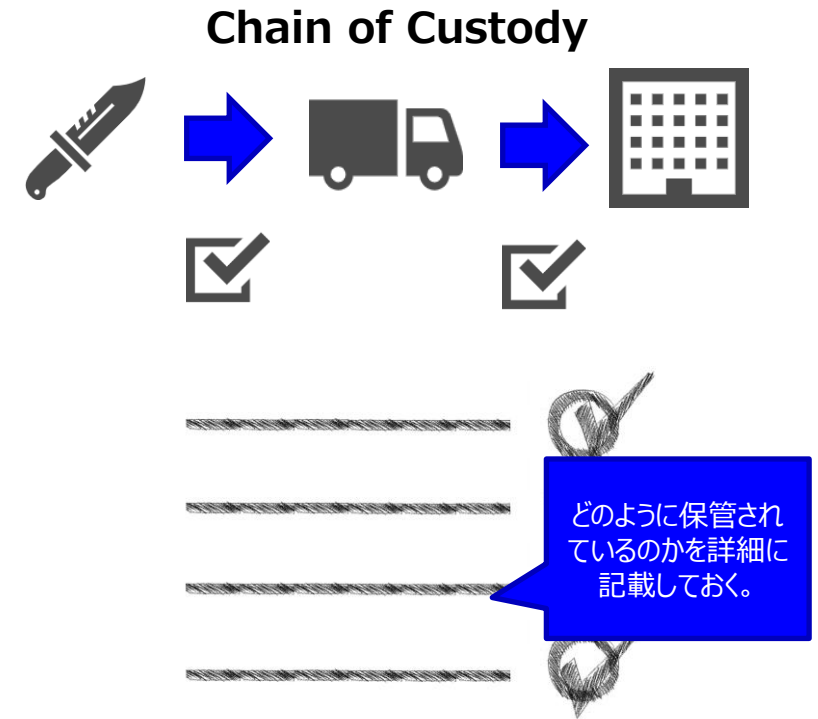
- ・ 伝聞は証拠とはならないという原則です。

最良証拠の原則（Best Evidence Rule）

- ・ 模造の証拠よりもオリジナルを優先するという原則です。

口頭証拠排除の原則（Parol Evidence Rule）

- ・ 書面にて合意した内容が口頭で合意したものと異なるとき、口頭による合意に拘束力があるとは限らないという原則です。
- ・ 口頭は対話だけではなく、メールでのやり取りも対象になります。





セキュリティドキュメント

セキュリティドキュメント

ポリシー・スタンダード・プロシージャ

●セキュリティドキュメント

ドキュメント区分	必須/任意	内容	例
ポリシー	必須	実現したいことを明確にします。	
スタンダード	必須	ポリシーを達成する上で必要な要素を具体化します。 ・ スコーピングとは、何のスタンダードを採用するかを決定することです。 ・ テーラリングとは、どのように組織に取り込んでいくかを決定することです。	ウィルス対策ソフト、アクセス制御システム、ファイアウォールシステム
ベースライン	任意	スタンダードを何に沿って決めたのか根拠です。	政府勧告、国際規格（ISO/IEC27001,27002等）、製品／システムの評価基準
ガイドライン	任意	ポリシーを実現するためのサポートです。	不正侵入検知システムの構成、アクセス制御システムの構成
プロシージャ	必須	どうやって達成するかをステップバイステップの手順です。	アカウント登録手順、ドキュメント作成・破棄手順書、インシデント対応手順



事業継続計画

事業継続計画

ビジネスインパクト分析（BIA）

●事業影響分析

事業影響分析/ビジネスインパクト分析（BIA、Business Impact Analysis）

- ・ 事業影響分析によって、組織のシステム、機能、活動の重要性と非重要性を特定します。
- ・ 主な目的は、関係者の部門にビジネスプロセスのリスクを認識させ、確認することです。より具体的に言うと、既存のあらゆる制御が機能しなくなった場合の最悪のケースを理解することです。
- ・ 主な活動として、クリティカルな箇所を特定します。クリティカルとは、破壊が許容できないと考えられる場合で、許容できるかどうかは回復コストにもよります。個人情報などの情報の保護が法律で定められている場合もその対象となります。これに加えて、経済的、政治的、社会的、環境的なリスクはないかを考慮します。
- ・ 事業影響分析は、DRP/BCPを策定する前の事前調査のプロセスに位置します。
- ・ 承認は経営者レベル以上で行われます。

調査

承認

対策

事業影響分析

上級管理者に
連携・説明

DRP/BCPの
策定

リアルな事業影響分析

事業影響分析はつまるところ“重要業務”を見つけ出すプロセスに当たります。しかし実際のところ、災害時に他を差し置いてでも率先してやり遂げなければならない業務は、日々の業務経験上わかっているものです。なので、改めて真なるビジネスの本質的な業務を探求するものでありません。

事業継続計画

ビジネスインパクト分析（BIA）

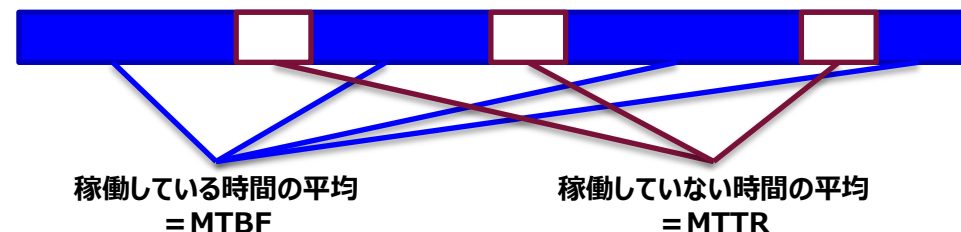
● システムの可用性

システム評価

- RASISとは、信頼性（Reliability、故障しにくいこと）、可用性（Availability、高い稼働率を維持できること）、保守性（Serviceability、障害から迅速に復旧できること）、完全性（Integrity、データの一貫性を保っていること）、安全性（Security、機密性が高いこと）の頭文字です。

稼働率による評価

- 平均故障時間（MTBF、Mean Time Between Failures）とは、新規または修理されたシステムやコンポーネントが、故障するまでの平均期間です。
- 平均修理時間（MTTR、Mean Time to Repair）とは、故障したシステムを復旧させるのにかかる平均時間です。
- 稼働率（Operation Radio）とは、システムのサービス提供稼働時間の比率を指し、可用性を示す指標となります。



稼働率を計る評価値

$$\text{稼働率 (\%)} = \frac{\text{MTBF}}{\text{MTBF} + \text{MTTR}} \times 100$$

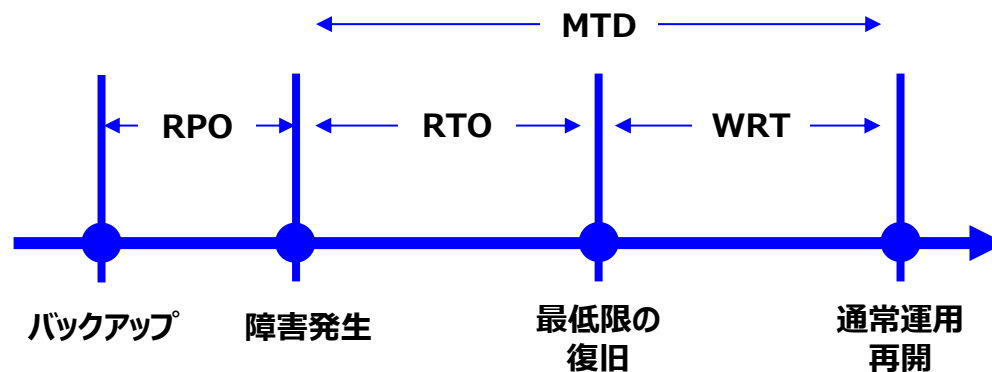
事業継続計画

ビジネスインパクト分析（BIA）

● 最大許容停止時間

事業復旧の目標値

- **目標復旧時点（RPO、Recovery Point Objective）**とは、いつ時点までのデータに復旧させるかを定めた目標値です。
- **目標復旧時間（RTO、Recovery Time Objective）**とは、障害発生時からクリティカルな機能（最小動作要件）をいつまでに復旧させるかを定めた目標値です。復旧と言っていますが、通常運用の時点に戻されているではありません。
- **業務復旧時間（WRT、Work Recovery Time）**とは、すべてのサービスとデータを復旧し、通常運用に戻すまでの時間です。
- **最大許容停止時間（MTD、Maximum Tolerable Downtime）**とは、障害が発生してから、本番環境に再投入するための設定を行う時間です。妥当なMTDとは、 $MTD \geq RTO + WRT$ であることを保証しなければなりません。



サービス復旧に関する用語の対応

重要度とサービスの復旧時間の目安

緊急度	復旧時間の目安
クリティカル	1-4時間
緊急	24時間
重要	72時間
通常	1週間

事業継続計画

ビジネスインパクト分析（BIA）

● 最大許容停止時間

最小動作要件

- **最小動作要件（MOR、Minimum Operating Requirements）**とは、重要なシステムが機能するために最低限必要な環境と接続の要件です。
- ビジネス機能を再開するために、フルスペックのシステムを必要としない場合もあります。再開を早急に望まれるのであれば、必要最低限の要点を押さえておくことが大事になってきます。

試験のテクニック

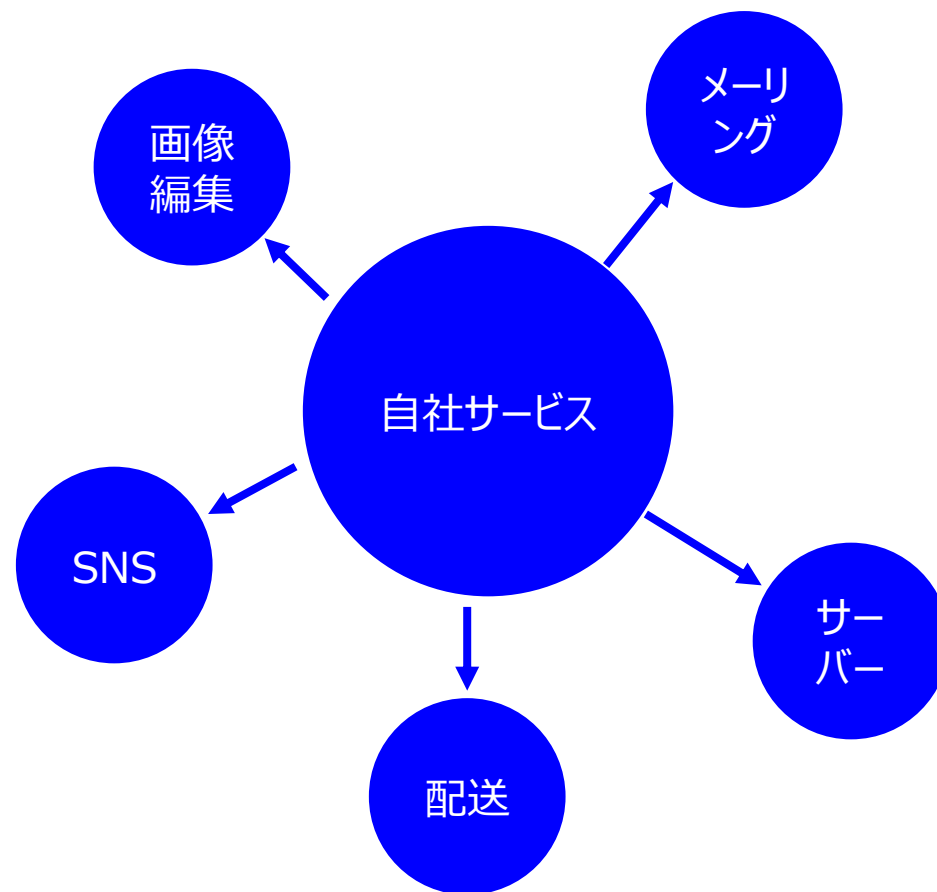
現実には、アプリケーションソフトウェアの製造過程で保証された動作環境の条件を示す場合もあります。ただ、試験ではアプリケーションの動作要件の文脈ではMORが使われることは少ないでしょう。

事業継続計画

外部依存関係

● 外部依存関係

- 企業サービスの機能の一部を、他社企業のサービスに頼っていることが多くあります。
- 事業継続を考えるうえで、他社企業の停止をきっかけに自身のサービスの停止に追い込まれる可能性があります。
- 例えば、あなたはECサイトを運営していたとします。ECサイトで発注された商品は別の配送会社に送ってもらう体系をしています。配送会社が事業停止に追い込まれたとき、あなたの商品の売り上げもめどが立たなくなる可能性があります。
- そうした場合、追加注文の停止、代替えとなる配送会社の手配等の作業を準備しておく必要があります。





人事セキュリティ

人事セキュリティ

候補者の審査と採用

●採用

書類選考と面接

- 職務記述書の必要とされる機密レベルに応じて分けられます。
- 候補者の職歴、学歴、推薦状、同僚へのインタビュー、逮捕歴、違法行為、SNSアカウント、個人面接が含まれます。
- 採用側は採用時に差別的な判定を下すことを禁止する規制を十分に認識することも重要です。
- 個人面接を行う場合でも各候補者を公平に扱うために、標準化された面接プロセスを持つことが重要です。

項目	内容
身元確認 (background check)	現在何者であるのか、社会的地位を確認することです。
経歴確認 (reference check)	社会人としてどのような歴史を持っているのかを確認することです。
教育資格確認 (education claim check)	どんな能力を持っているかを確認することです。

人事セキュリティ

雇用契約と方針主導

●入社

職務記述書（ジョブディスクリプション）

- 職業内容が記載された文章です。
- 従業員として雇用した後も職務記述書を保持し、職務記述書に即した活動ができているかを比較することができます。

オリエンテーション

- 組織としての社会的意義や、組織のルールを説明します。
- 仕事の満足度の向上、生産性の向上、組織への忠誠心の向上、ストレスの軽減、退職の減少につなげる狙いがある。

職務記述書のサンプル

項目	概要
職務名	セキュリティコンサルタント
職務目的	企業のリスクに関する継続的評価と対応
職務内容	セキュリティのプロジェクト推進対応
必要な知識・スキル	CISSP
勤務条件	9:00～17:30
休日・休暇	完全週休二日(土日) 祝日、年末年始、暑中休暇、リフレッシュ休暇
福利厚生	通勤手当、財形貯蓄制度、保養所、各種スポーツ施設

人事セキュリティ

雇用契約と方針主導

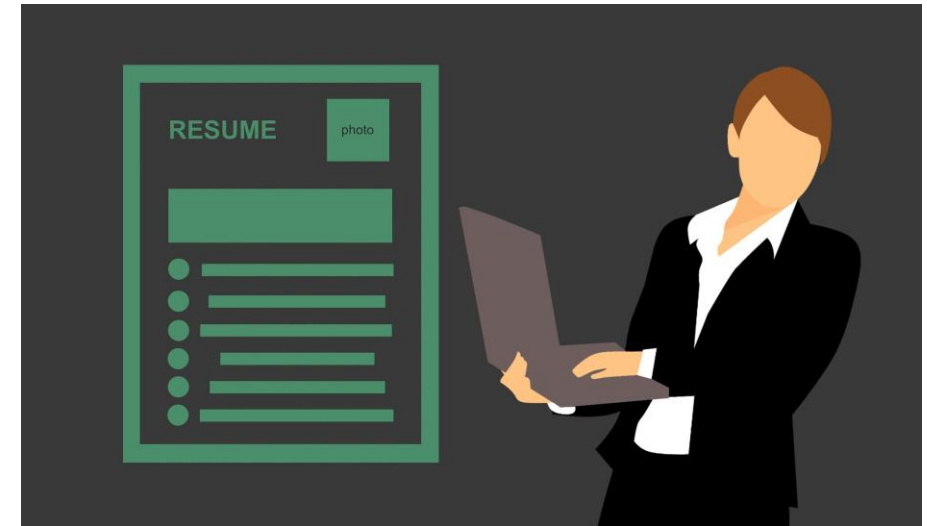
● 契約書類

雇用契約書

- 一般的には、新入社員を組織に加え、雇用契約や方針を確認し署名させ、マネージャーや同僚を紹介し、社員の業務や物流に関するトレーニングを行うプロセスが行われます。
- 従業員の方が雇用契約書に署名する時には、組織の規則、職務内容、違反行動、試用期間といったものが記載されています。
- 違反の場合には、職務上の警告、罰則、最悪解雇につながる可能性があります。

秘密保持契約（NDA、Non-Disclosure Agreement）

- 取引上で知った相手方の営業秘密などを他人に開示することを禁止する契約のことです。
- 秘密保持契約は従業員として雇われるときや、その従業員の責任が変わった時にも再度署名が求められます。退職する際にも漏洩しないことは法的な義務であるということを、この秘密保持契約によって再確認する必要があります。



人事セキュリティ

雇用契約と方針主導

● 契約書類

競業避止義務（NCA、Non-Complete Agreement）

- 従業員が雇用主に対する競争に参加しないことを約束する契約です。
- 会社と競合する他社に就職及び競合する事業を営むことを禁止します。

就業規則の規定例

（競業避止義務）

第〇〇条

従業員は在職中及び退職後 6 ヶ月間、会社と競合する他社に就職及び競合する事業を営むことを禁止する。ただし、会社が従業員と個別に競業避止義務について契約を締結した場合には、当該 契約によるものとする。

経済産業省

<https://www.meti.go.jp/policy/economy/chizai/chiteki/pdf/handbook/reference5.pdf>

人事セキュリティ

入社・異動・解雇

●退職

- ・退職というネガティブなイベントでは、突飛な行動や不誠実な行動が発生する可能性があります。
- ・組織によっては退社面接もしくは出口面接を設けます。従業員がなぜ退職するのか、組織をどのように見ているのか、改善案を聞き出し対応することで、いい人材の流出を防ぎます。

出口面接

- ・指導とは、辞めるにあたり何を実施すべきかを説明することです。
- ・ディスカッションとは、一方的に進めるとことを荒立てる可能性があるため、相手の意見も聞くことです。
- ・口頭での警告とは、口頭にて禁止事項を警告することです。記述での警告とは、紙面にて禁止事項を警告することです。

退職時のアカウント管理

- ・アカウント管理システム（IAMシステム）で対象従業員のIDは停止されます。



人事セキュリティ

ベンダーとの契約管理

●ベンダー管理システム

- 取引先となるベンダーの調査と選定、契約交渉などのサプライヤー管理を行うシステムです。
- 財務状況や十分な体制を持っているか、ISOといった業界標準の組織体制を維持しているか確認し、選定します。

サプライチェーンとの統合

- 選定したベンダーに対して、注文書から署名の依頼、納品の確認、一元的に管理できるようになっています。

ベンダーの評価

- 契約が終了したら、そのベンダーに対するアンケートを取ります。



ベンダーA



ベンダーB



ベンダーC



ベンダーD



ベンダーE

	財務健全性	標準認定	統合評価
ベンダーA	○	○	○
ベンダーB	○	×	×
ベンダーC	○	×	×
ベンダーD	×	○	×
ベンダーE	○	○	○

ベンダーA、ベンダーEに依頼内容を説明し、相みつを取ります。



リスクマネジメント

リスクマネジメント

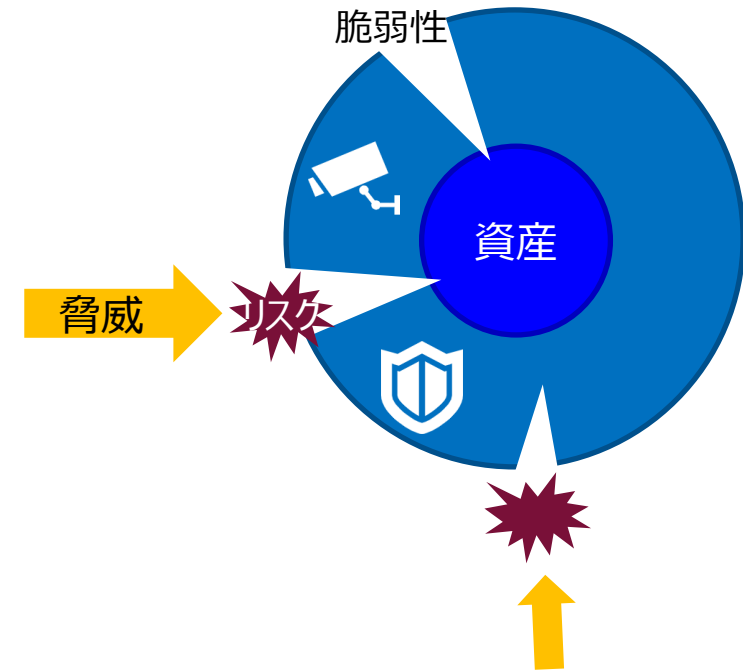
脅威と脆弱性の特定

●リスクとは

リスク = 脅威 × 脆弱性

- 脆弱性に対する脅威があるときにリスクは生じる。逆に言えば、脆弱性があってもそれを攻撃する脅威がなければ、リスクとはならない。
- リスクは、脅威と脆弱性の両方の大きさにより、その規模が変わる。

$$\text{リスク} = \text{脅威} \times \text{脆弱性}$$



リスクマネジメント

リスクの分析・評価・範囲

● 定性分析（リスク分析マトリックス）

アンケート結果など費用として評価できない、するべきでない事象に対して定性的な評価を行います。

例 1：他者競合のサービス展開

- 他者競合のサービスは、公開されるまでどのようなサービスかは不明確であることから影響コストとしての計上ができません。
- しかし、自社のサービス機能を織り込んでくることが考えられるため、影響大きいと判断がつきます。

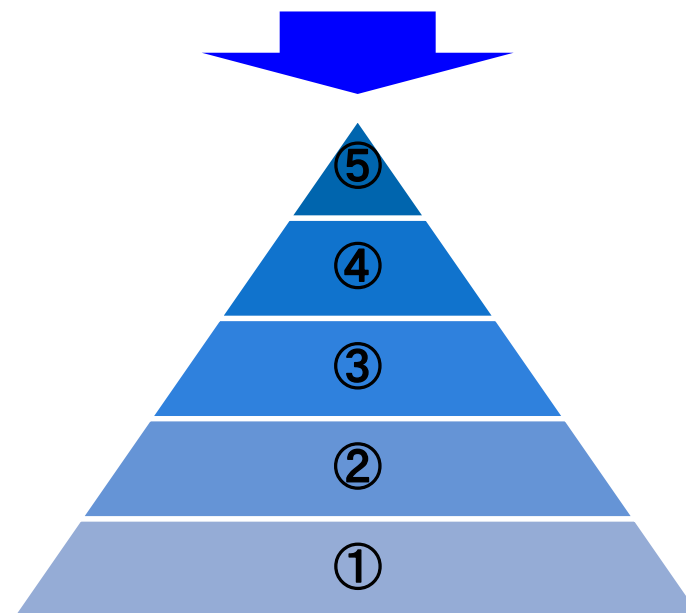
例 2：新サービス展開による問い合わせ対応

- 新サービスの展開は、どのような問題が出てくるのかわかりませんが、問い合わせの中で解消可能と考えられるのであれば、ある程度のコストを見込んでおけば解消可能となるため、影響度合いは中と判断がつきます。

例 3：地震

- 地震は、地震の規模によって影響度合いが異なりますが、施設の破壊などにつながるため、影響大きいと判断がつきます。

	発生確度			
		小	中	大
影響度	小	①	②	③
	中	②	③	④
	大	③	④	⑤



リスクマネジメント

リスクの分析・評価・範囲

● 定量分析（年間予想損失額）

各リスクを洗い出したうえで、現状と対応策の状態に対して、1年間で発生する損失する額となる年間予想損失額（ALE, Annualized Loss Expectancy）を計算し比較します。

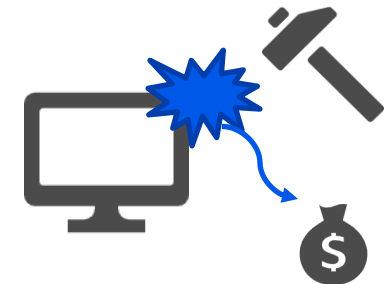
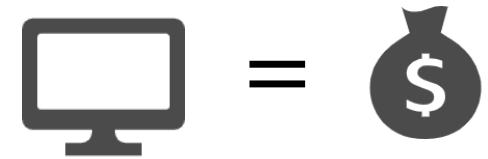
STEP1 資産の特定と資産価値の算出

- 資産価値（AV, Asset Value）の算出します。
- マーケットアプローチとは、市場で似た資産を参考にします。収益アプローチとは、将来的に稼ぐであろう利益で計ります。コストアプローチとは、資産に使ったコストで計ります。

STEP2 損失資産の計算

- もしリスクが発生した場合に無くなる価値の割合である暴露係数（EF, Exposure Factor）と1つの資産の内に損失する額である単一損失予想（SLE, Single Loss Expectancy）を算出します。

$$SLE = AV \times EF$$



リスクマネジメント

リスクの分析・評価・範囲

● 年間予想損失額（Annual Loss Exposure）の計算

STEP3 脅威分析から年間の発生回数を算出

- 脅威分析から1年間で発生する回数となる年間発生率（ARO, Annualized Rate of Occurrence）を算出します。

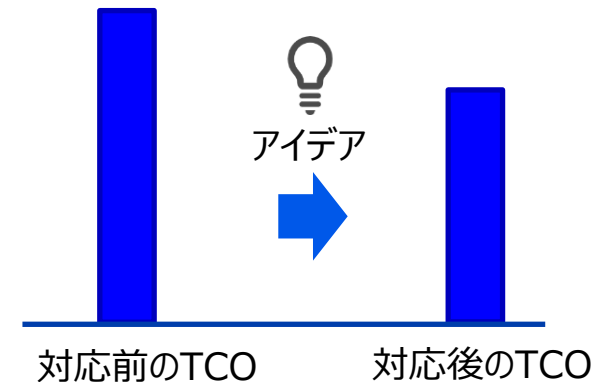
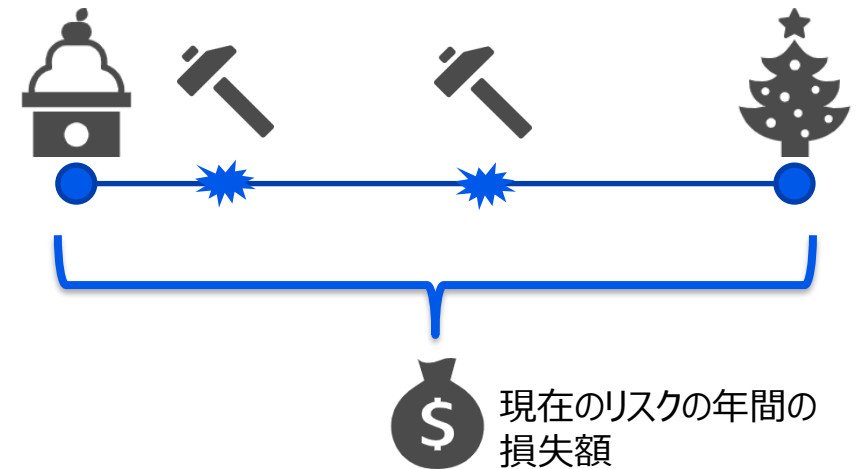
STEP4 年間予想損失額を計算

- 1年間で発生する損失する額となる年間予想損失額（ALE, Annualized Loss Expectancy）を算出します。

$$ALE = SLE \times ARO$$

STEP5 コスト/利益分析を実行

- STEP1～STEP4の計算は一つの資産に対して計算になります。TCO（Total Cost of Ownership）は、すべての資産のALEを足し合わせた、いわゆる総コストです。
- 新たな対策案のTCOと比較し、低ければ投資対効果（ROI, Return On Investment）が高いということになります。



リスクマネジメント

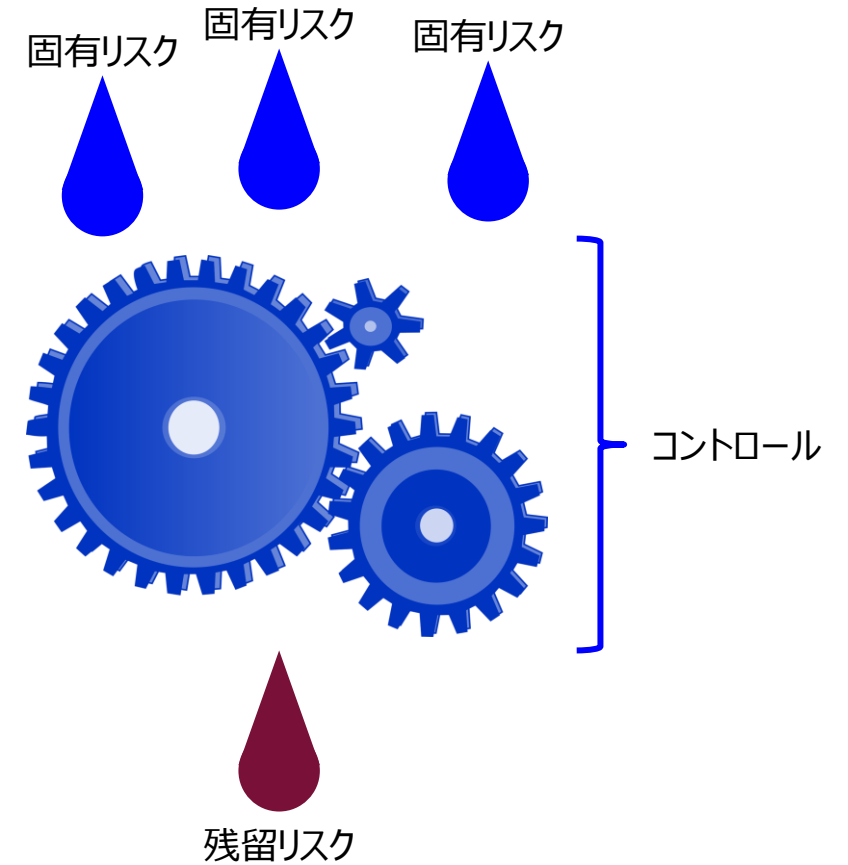
リスクの分析・評価・範囲

● 残留リスク (Residual Risk)

残留リスク

- リスク対策をしても存在し続けているリスクです。
- 解決できなかったリスクを残留リスクといい、年間予想損失額（ALE）に達成できなかった割合（コントロールギャップ）をかけ合わせて算出します。

$$\begin{aligned} &\text{残留リスク (RR)} \\ &= \text{年間予想損失額 (ALE)} \\ &\quad \times \text{コントロールギャップ} \end{aligned}$$



リスクマネジメント

リスクへの対応と処置

●リスク対応策の選定

リスクの評価が完了した後は、各リスクに対する対応策を考えます。その際に各リスクの規模と発生頻度に応じて、対応方法も異なります。

リスク軽減

- 致命的でなく、発生頻度が高い場合、修正してリスクを減らす対応方法です。

リスク回避

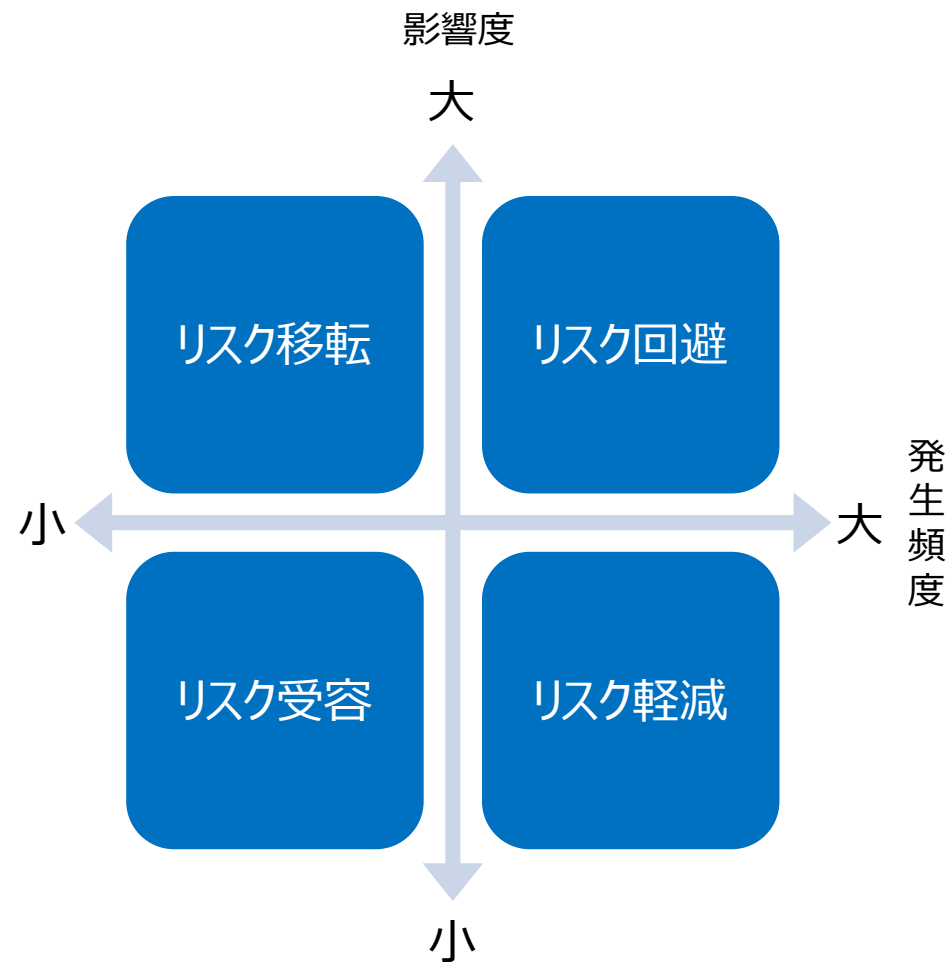
- 致命的であり、発生頻度が高い場合、排除する対応方法です。

リスク移転

- 致命的であり、発生頻度が低い場合、保険などリスクを請け負ってもらう対応方法です。

リスク受容

- 致命的でなく、発生頻度が低い場合、リスクを受け入れてしまう対応方法です。



リスクマネジメント

適用可能な管理策

● アクセスコントロールタイプ[°]（手段）

管理的コントロール

組織制度によるコントロール



教育



ガイドライン

技術的コントロール

情報システムによるコントロール



ソフトウェア



アクセス制御設定



ハードウェア

物理的コントロール

物体によるコントロール



ドア



フェンス

リスクマネジメント

適用可能な管理策

● アクセスコントロールタイプ（性質）

名称	内容	例
行動指示的（directive）	管理として従業員に求められる行動を指示する目的のコントロールです。	教育
抑止的（deterrent）	攻撃の前から飽きらめさせる目的のコントロールです。	警備犬、警備標識
物理的（physically）	物理によるコントロールです。	ドア、壁、フェンス
防止的（preventive）	攻撃のやりにくさを上げる目的のコントロールです。	フェンス
検知的（detective）	違反者を見つける目的のコントロールです。	CCTV、アラーム、ログ
補強的（compensating）	他の防御に加えて防御力を上げる目的のコントロールです。	ドローン監視
復旧的（recovery）	障害が発生してしまった場合に、早急に回復する目的のコントロールです。	バックアップ
是正的（corrective）	今後、障害が起きさないよう改善する目的のコントロールです。	再発防止策立案、ACL更新

リスクマネジメント

コントロールの評価

●コントロールの評価

セキュリティ管理評価

- セキュリティとは、機密性・完全性・可用性を保護することを目的とします。
- 例として、リスクアセスメントを実行していること、脆弱性スキャンやペネトレーションテストを行っていることが挙げられます。

プライバシー管理評価

- プライバシーとは、個人の権利を尊重し、不適切なデータ使用や情報漏洩を防ぐことを目的とします。
- 例として、ユーザーからCookieの取り扱いや登録する個人情報に対して、同意を取得し、同意の内容に沿った運営を行うことが挙げられます。

セキュリティ管理評価



- リスクアセスメント
- 脆弱性スキャン
- ペネトレーションテスト

機密性・完全性・可用性の保護

プライバシー管理評価



- GDPRに準拠したCookie承諾
- 個人情報保護
- オプトイン・オプトアウト

プライバシーの保護

リスクマネジメント

1.9.6 継続的モニタリング

● 継続的モニタリング

継続的モニタリング

- 継続的モニタリングは、組織がリアルタイムでリスクを特定し、監視することを指します。
- 継続的モニタリングは、組織のリスク状況を最新の状態かどうかを把握することを主な目的にします。
- リスクがいつ顕在化するかわからない、急速に進化する今日のビジネス環境においては特に重要です。



特定の口座の取引量が異常に増加している



マネーロンダリング？



患者データのプライバシーとセキュリティを追跡



データ保護規制へのコンプライアンスを確保



否定的なレビューが増加している



潜在的な品質問題がある？

リスクマネジメント

報告

● 業務受託会社監査

業務受託会社監査（SOC、Service Organization Control）

- 米国公認会計士協会（AICPA）によって決められている業務の請け負い側の内部統制を保証するための決まりのこと。

SOC-1（Internal Control over Financial Reporting）

- 受託会社が委託されている業務のうち、委託会社の財務報告に係る内部統制の適切性・有効性を対象とした保証報告書です。

SOC-2（Trust Services Criteria）

- 受託会社が委託されている業務で、セキュリティ、可用性、処理のインテグリティ、機密保持、およびプライバシーに関連する内部統制を対象として保証を受けた報告書です。

SOC-3（Trust Services Criteria for General Use Report）

- セキュリティに関連する内部統制について合理的な保証を提供します。
- 報告書の構成は概括的な記載となっており、開示範囲が制限されていないことから、インターネットを通じて報告書を公開することができます。

リスクマネジメント

継続的改善

● リスク成熟度モデル

リスク成熟度モデル（Risk Maturity Model）では、以下の3つの評価項目について1～10の尺度で採点されます。

有効性（Effectiveness）

- 主要なリスクマネジメント活動の頻度と有効性を測定する。
- アセスメントは一度きりか、毎年実施されているか？

積極性（Proactivity）

- リスクマネジメントの性格を測定する。
- 事象が発生するまで待っているか、予想しているか？

対象範囲（Coverage）

- 組織内のリスクマネジメントの対象が広範囲であるか。
- 組織の全部門及び全階層にわたってアセスメントされており、責任者が設けられているか？



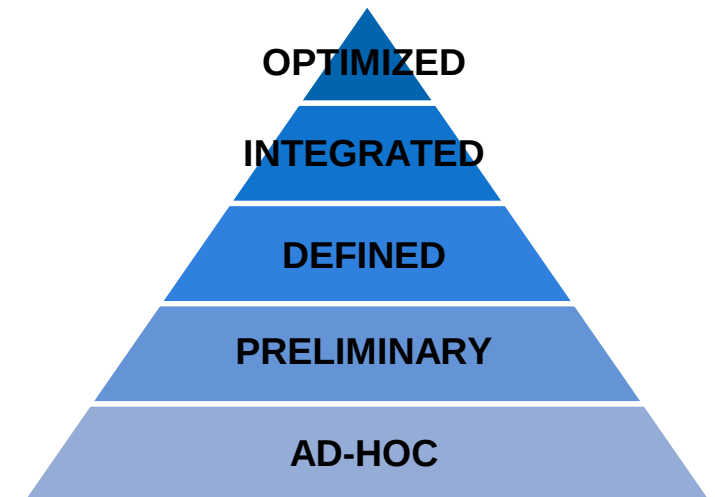
有効性
(Effectiveness)



積極性
(Proactivity)



対象範囲
(Coverage)



リスクマネジメント

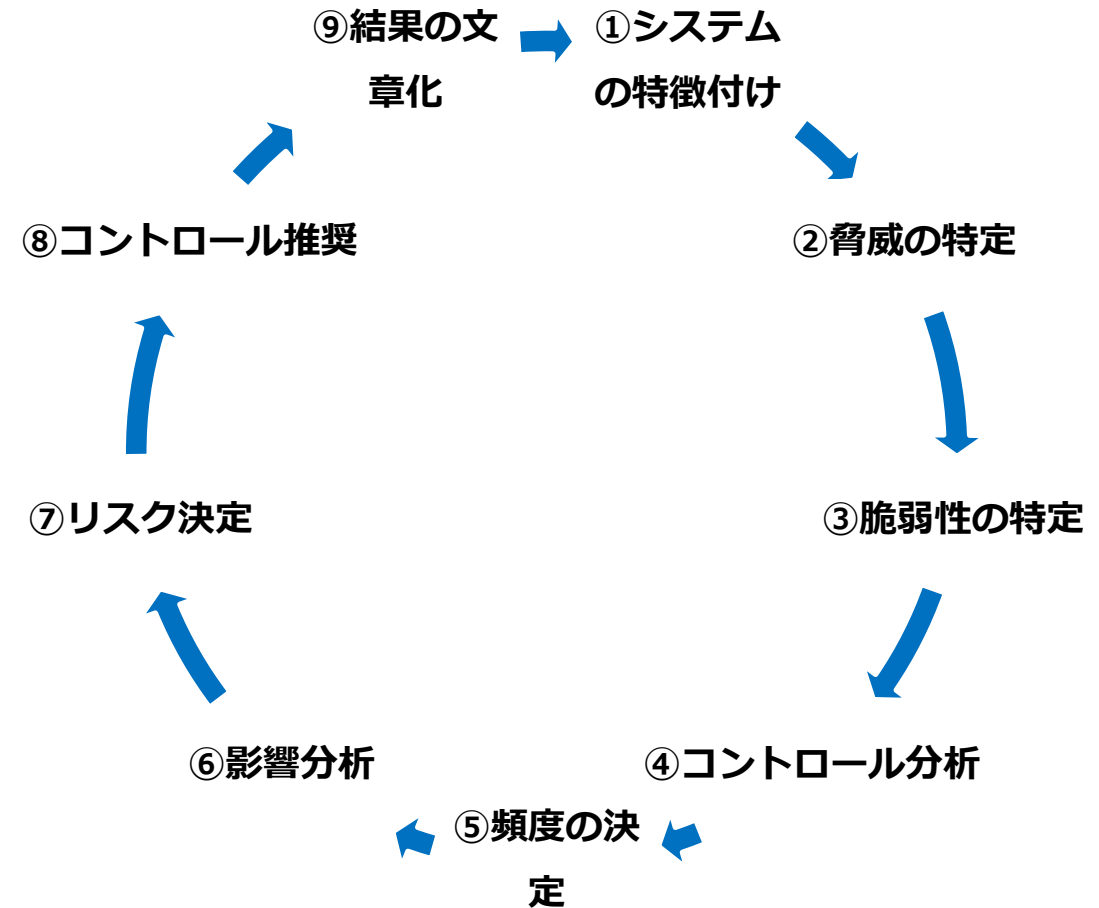
リスクフレームワーク

●リスクフレームワーク

改善プロセスと同様にリスク分析も修正したら終わりではなく、繰り返し続ける必要があります。

リスクアセスメントの実施の手引き（NIST SP 800-30）

- リスク評価のプロセスは、NISTで定義されています。
(<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>)





脅威モデリング

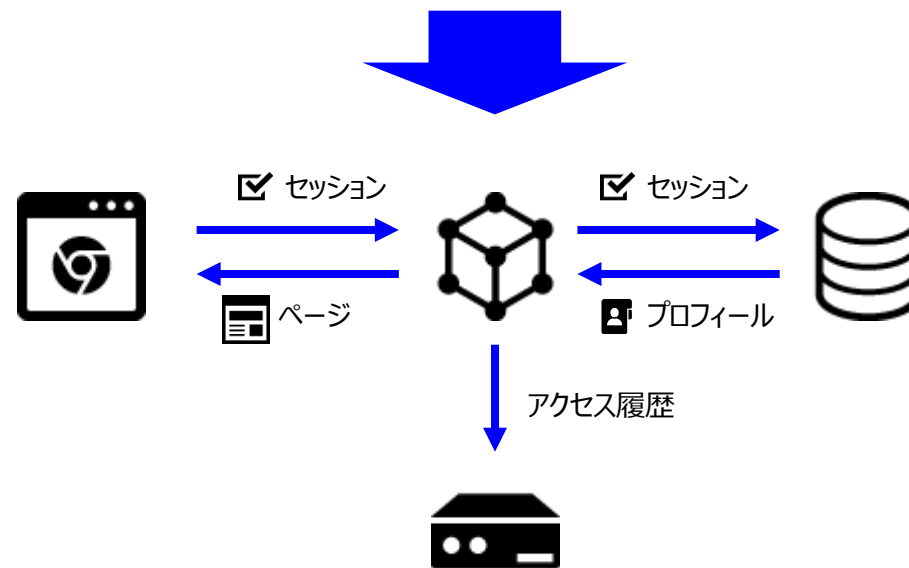
脅威モデリング

脅威分析

● 脅威モデリングの基本 脅威モデリング

- 脅威モデリングとは、アプリケーションのアーキテクチャに起こりうる脆弱性を事前に特定する手法のことです。
- プロセスとしては、STRIDE、確率×被害可能性ランキング、DREAD評価システム、PASTAがあります。
- どのようなプロセスであってもまずは対象システムの図示をすることが推奨されます。
- 図示することで認識が明確になり、脅威の特定がより効率的になります。

「このアプリケーションは、WEBブラウザからアクセスすると、そのセッションに紐づいた情報をデータベースから引き出し、画面に整形し、ブラウザに返却します。そのアクセス記録は、アクセス管理サーバーに送付され、リアルタイムに管理できます。」



脅威モデリング

脅威分析

● STRIDE

多くのシステム製品に見られる代表的な6つの脅威の頭文字のことです。脅威の特定に利用することができます。

- なりすまし（Spoofing）とは、ある人が別の人を詐称して利用する行為です。
- 改ざん（Tampering）とは、データが本来なされるべきでない形式や内容などに変更されることです。
- 否認（Repudiation）とは、事実として認めないこと、認めるほどの証拠を収集できていない状態です。
- 情報漏洩（Information disclosure）とは、機密情報や個人情報など保有している重要データが外部に漏れてしまうことです。
- サービス不能（Denial of service）とは、資源に対するアクセスができないように妨害したり、遅延させたりすることです。
- 権限昇格（Elevation of privilege）とは、あるユーザを対象として権限付与された権限や特権を超えて、不当なアクセス権限を得ることです。

● DREAD評価システム

ある脅威が自身にとって脅威となりうるか、どの程度脅威であるのか判断するための評価項目です。

- 被害の可能性（Damage potential）とは、自身の資産への被害が出る可能性を示します。
- 再現可能性（Reproductivity）とは、実証可能であるかを示します。
- 攻撃利用の可能性（Exploitability）とは、実際の攻撃に転じるかを示します。
- ユーザー影響（Affected users）とは、顧客に対して影響が出るかを示します。
- 発見の可能性（Discoverability）とは、攻撃された場合に発見可能かを示します。

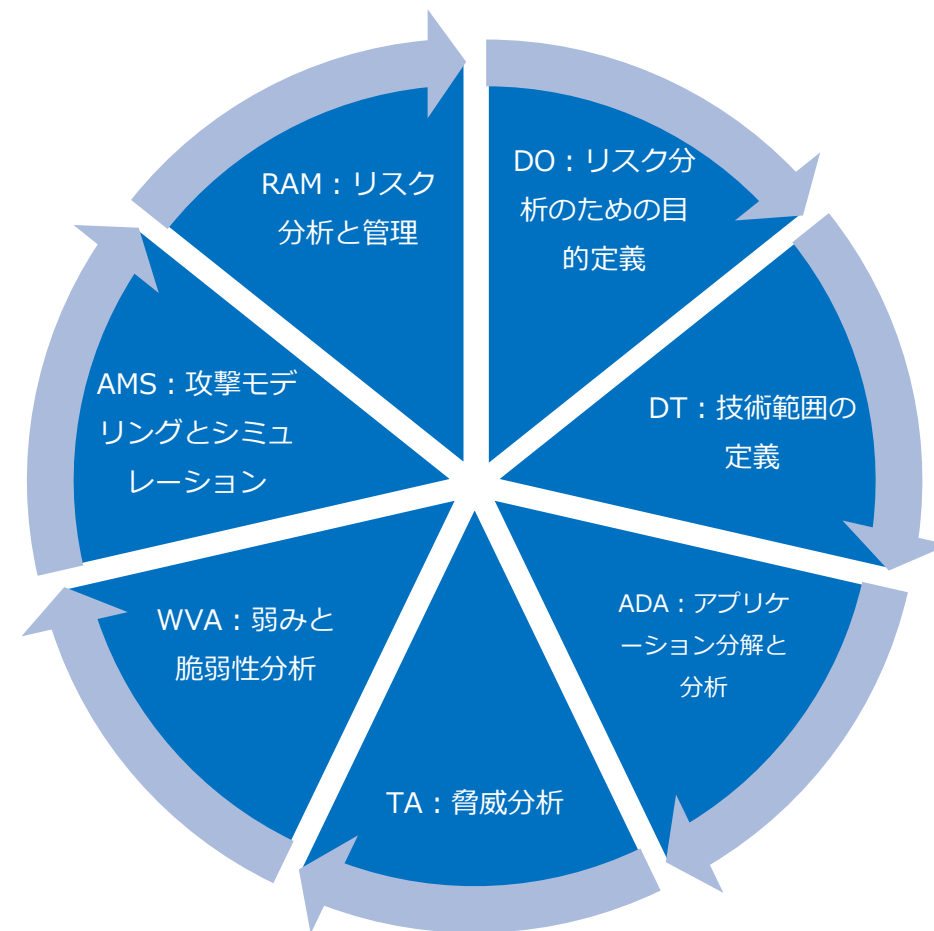
脅威モデリング

脅威分析

● P.A.S.T.A.

コンプライアンスとビジネス分析しながら、資産価値を保護する方法を見つける7ステップのことです。

P.A.S.T.A.を使用すると、組織はアプリケーションとインフラストラクチャに対する攻撃者の視点を理解できるため、脅威管理プロセスとポリシーを発見できます。



P.A.S.T.A.のサイクルプロセス



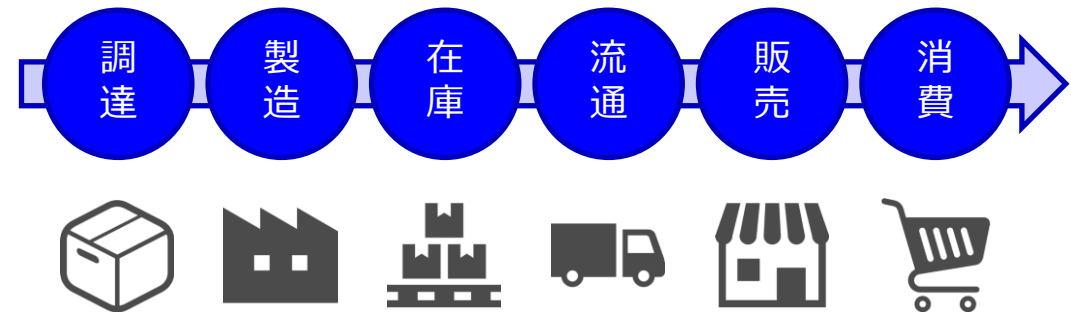
サプライチェーンリスクマ ネジメント (SCRM)

サプライチェーンリスクマネジメント

サービス取得に関するリスク

● サプライチェーンマネジメント

- サプライチェーンマネジメントとは、原材料調達から生産加工や在庫管理、流通や販売、各プロセスに携わる物流など、商品の開発から消費者の手に渡るまでの一連の流れを管理することです。サプライチェーンの目標は、最終的な完成品が十分な品質を保っている事です。
- リスクベースのマネジメントの概念をサプライチェーンに適用することで、あらゆる規模の組織がより強固なセキュリティ戦略を確保することができます。
- ほとんどのコンピュータ、デバイス、ネットワーク、システム、クラウドサービスも単一の事業者によって開発されているわけではありません。そのため、どの要素でも偽装され、不完全なものが入り込む余地があります。
- ハードウェアではなく、ファームウェアやソフトウェアも改造されている可能性もあります。そのため、検査よりも信頼できる評判の良いベンダーから製品を調達したり、国内で製造しているベンダーにして限定しているケースも見受けられます。



サプライチェーン

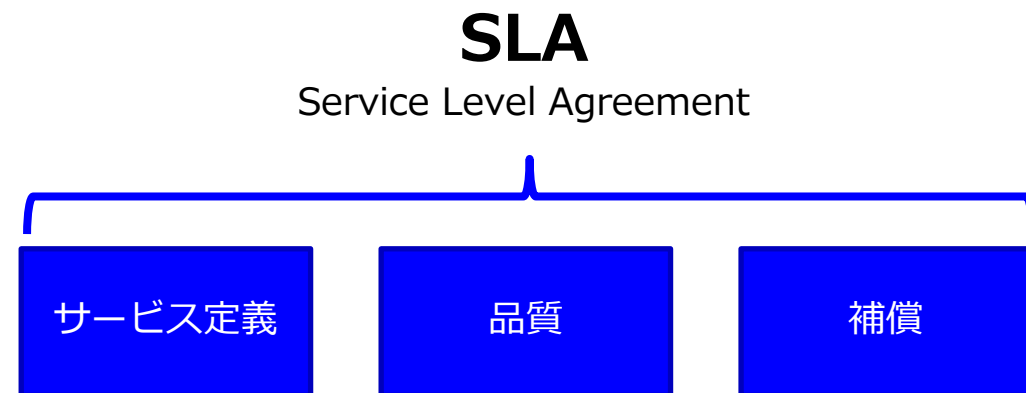


サプライチェーンリスクマネジメント

リスク軽減策

● サービスレベル合意書（SLA）

- 利用量や障害復旧などのサービス品質の合意になります。
- クラウドといったインフラ設備やプラットフォームに対して、システム稼働における可用性や性能といった品質項目と水準を定めます。
- サービスの質が保たれることを買い手に安心してもらうために、サービス提供者側は合意を取るのです。基盤のシステムを借用するクラウドサービスでは、障害時のSLAがどのようなになるのかは確認しておきましょう。





セキュリティ意識向上と 教育プログラム

セキュリティ意識向上と教育プログラム

ソーシャルエンジニアリング

● ソーシャルエンジニアリング

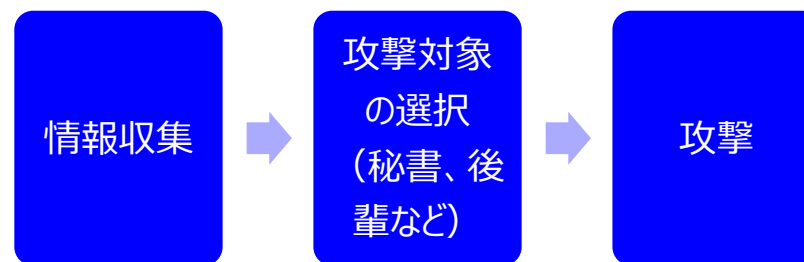
- ・ システムではなく人的ミスを誘う攻撃です。
- ・ 特定の方法があるのではなく状況に応じて変わります。
例えば、ヘルプデスクに本人を装って個人情報聞き出ししたり、本人を脅して直接聞くことなどが当たります。セキュリティ事故の原因で最も多いと言えるのがソーシャルエンジニアリングです。

例 1 : サボタージュ

- ・ 裏切りなど内部の人間に攻撃されることです。
- ・ 外部から攻撃に対しては堅守しているが、内部からの攻撃は容易であることを悪用されます。

例 2 : 結託 (collusion)

- ・ 集団投票など、2人以上によって行われる不正行為です。



ソーシャルエンジニアリングの攻撃の過程

援助	「パスワードをなくして困っています。」
緊急性	「火事のようなです。建物を検査させてください。」
従順	「CEOが資料を提出してほしいそうです。」
ペナルティ	「早く対応しないと罰金になります。」
希少性	「今だけ特別です。」

言い回しによる誘導

セキュリティ意識向上と教育プログラム

意識向上とトレーニング

● 意識向上とトレーニング

意識向上 (Awareness)

- セキュリティを軽視しないように定期的に行う注意喚起です。
- 新しい脆弱性への対応策などではなく、すでに知っている事柄を対象します。
- 朝礼、ポスターを張るなどが意識向上に当たります。

トレーニング (Training)

- 最新の脅威などについてセキュリティ知識を広げる行為です。
- 専門の仕事以外にもトレーニング (**クロストレーニング**) し、ナレッジに偏りを解消し特定の人がないになった場合にビジネス継続します。

トレーニング

知識の向上

最近のセキュリティ
インシデント、社内
ポリシーの改定の連
絡

意識向上

知識の維持

社内ポリシーや順守
すべき法律の通知、
パワハラなどの倫理
的問題の注意喚起

セキュリティ意識向上と教育プログラム

意識向上とトレーニング

●ゲーミフィケーション

- 本来ゲームではないものを、報酬やランキングというシステムを導入することでゲーム化して、トレーニング効果を高める活動にすることです。
- 例えば、ランキングや順位に応じて報酬を与える。

●セキュリティチャンピオン

- セキュリティチャンピオンとは、開発チームのなかでのセキュリティの代表者です。
- 最も知識があるとか、気を付けているとかいうわけではありません。関心が高くチームのセキュリティを代表するような人物が選出されます。



ゲーミフィケーション



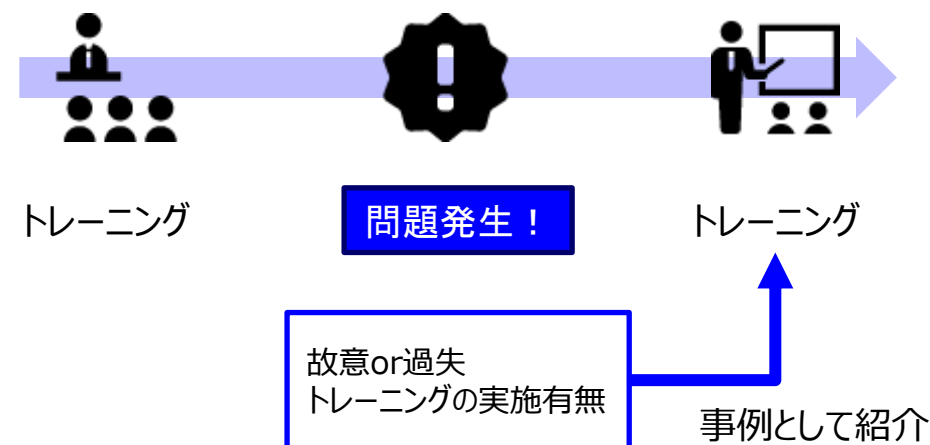
セキュリティチャンピオン

セキュリティ意識向上と教育プログラム

意識向上とトレーニング

●プログラムの有効性評価

- 社内でトレーニングを受けさせるだけではなく、そのトレーニング後にセキュリティインシデントが減ったのか増えたのか、こういったものが発生したのかという事後分析を行うことも求められます。
- トレーニングを受けたのにセキュリティインシデントを起こしてしまっている場合には、同様のケースを起こさないためにトレーニング内容を見直す契機になります。



セキュリティ意識向上と教育プログラム

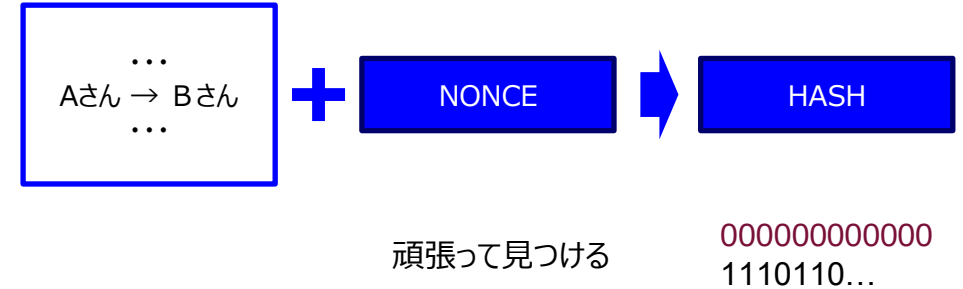
新しい技術やトレンド

●ブロックチェーン ブロックチェーン

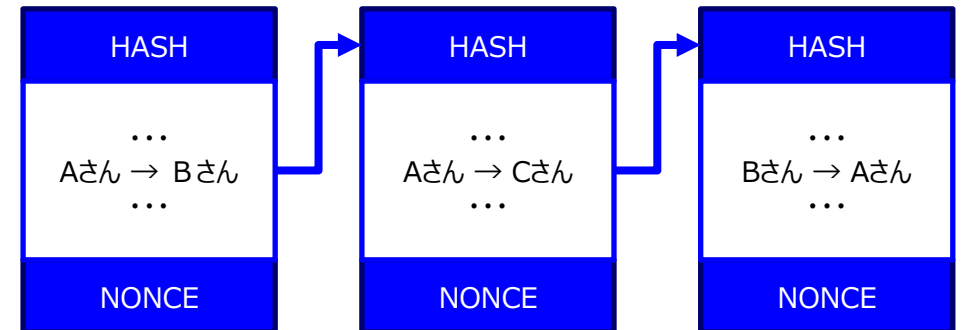
- ブロックチェーンは非中央集権型の元帳管理システムであり、元帳を取引母体が持っています。

Proof of Work

- 先頭数個の0が続くハッシュ値を発見した人が、そのデータを承認して正しくブロックチェーンにつなぎこむ役割を担う仕組みがあります。
- もしも、あるブロックの取引を勝手に変更したとき、自分の延々と前にあるブロックのハッシュ値を算出しなければなりません。
- この値を見つけるのは“頑張る”しかありません。この頑張って計算してくれる母体を（仮想通貨）マイナーと言います。



ハッシュ関数は任意の文字列に対して固定長のビット列を返却する関数です。



Proof of Work

セキュリティ意識向上と教育プログラム

新しい技術やトレンド

●人工知能（AI、Artificial Intelligence）

- 人間や他の動物ではなく、機械が示す知能です。学習や問題解決など、人間が他の人間の頭脳と関連付ける認知機能を機械が模倣する場合にも使われます。
- 人工知能という言葉は、1956年にアメリカのダートマス大学で開かれた研究会議で生まれました。

エキスパートシステム

- 人間の専門家の意思決定能力を模倣したコンピューターシステムです。
- 従来の手続き型コードではなく、主にif-thenルールとして表現された知識を推論することで複雑な問題を解決するように設計されています。エキスパートシステムは2つのサブシステムに分かれています。知識ベースは事実とルールを表します。推論エンジンは、ルールを既知の事実に適用して新しい事実を推論します。
- しかし、懸念点としては知識ベースにないものはデータがないものは範囲外として扱われ、対応できない特性があります。

人工知能

コンピュータに人間のような知能を持たせる。

機械学習

データを集計し、コンピュータが学習すること。

ニューラルネットワーク

人口ニューロンにデータを流し、脳のように情報を処理する。

ディープラーニング

ニューラルネットワークの手法を発展させたもの。

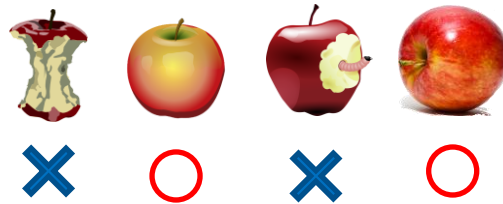
セキュリティ意識向上と教育プログラム

新しい技術やトレンド

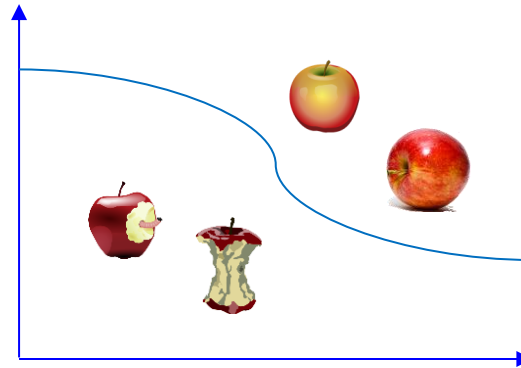
●機械学習

- データを分析する方法の1つで、コンピューターが自動で学習し、データの背景にあるルールやパターンを発見する方法です。
- 機械学習の類義語として人工知能（AI）がありますが、人工知能を実現するためのデータ分析技術の1つが機械学習です。
- 教師あり学習では、データに対する正解を与え、答え合わせを繰り返し行います。教師なし学習では、データに対する正解を与えず、入力したデータからパターンを見出します。

教師あり学習



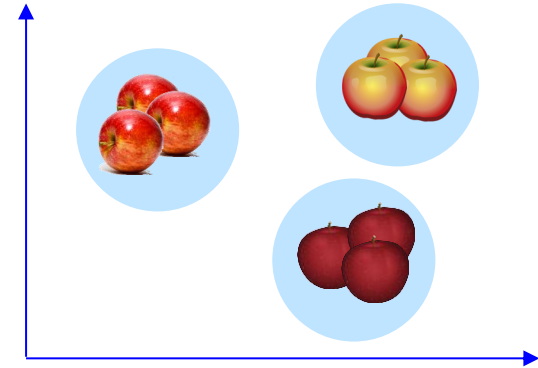
「出荷できるか」、「出荷できないか」のように正解を与えてあげる。答え合わせを繰り返すことで、「どのぐらい」がわかるようになる。



教師なし学習



パターンを探し出し、区分し、傾向や特徴を見つける。異常検知にも役立つ。



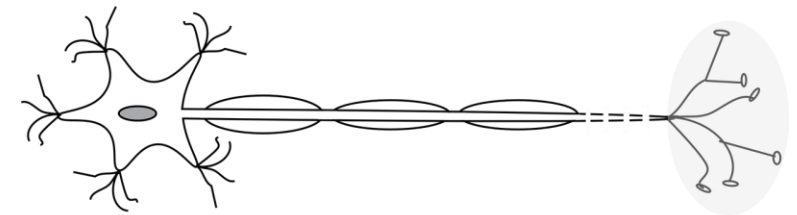
セキュリティ意識向上と教育プログラム

新しい技術やトレンド

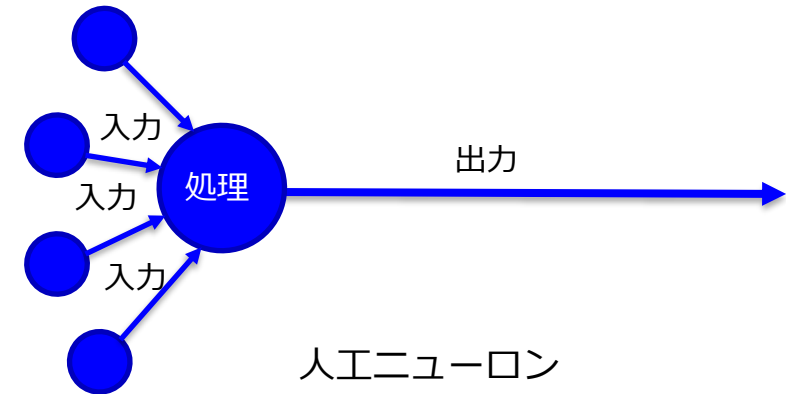
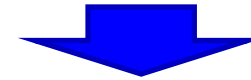
●ニューラルネットワーク

ANN(Artificial Neural Network)

- 人間は多くの記憶、物語、状況、その他多くの要素に基づいて判断を下しており、その意思決定をANNは模倣しようとします。
- 神経細胞（ニューロン）のように人工ニューロンは複数の入力を引数として、その引数にいくつかの算術を行い、ある数値を出力します。
- ニューロンネットワークでは、多数の人工ニューロンを複数の層に分けてつなぎ、情報を処理します。ニューロン間の各接続（シナプス）は、別のニューロンに信号を伝達することができます。ニューロンは通常、層で構成されており、異なる層は入力に対して異なる変換を行います。信号は最初の入力層から最後の出力層まで、時には複数の層を経由して伝わります。



神経細胞

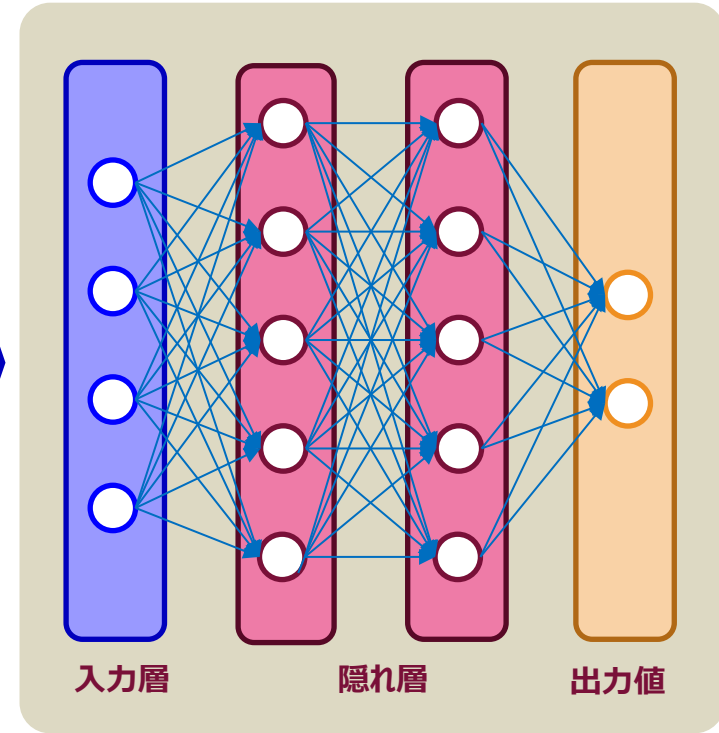


セキュリティ意識向上と教育プログラム

新しい技術やトレンド

●ニューラルネットワーク ディープラーニング（深層学習）

- ディープラーニングとは、ニューラルネットワーク手法を発展させ、人工ニューロンを更に多層化したものです。
- ディープラーニング以前は、どの特徴に注目すべきかを人が指示する必要がありました。ディープラーニングでは大量の画像を読み込ませることで注目すべき特徴を決定することができます。
- 学習段階の大量の画像を読み込ませる作業は、各層の重みづけの調整に当たります。
- 多層化することで、入力層に近い層では、元の画像を単な図形として解釈しますが、出力層に近い層では、複雑な形状に対応する信号を扱えるようになります。



人がいる
確率90%



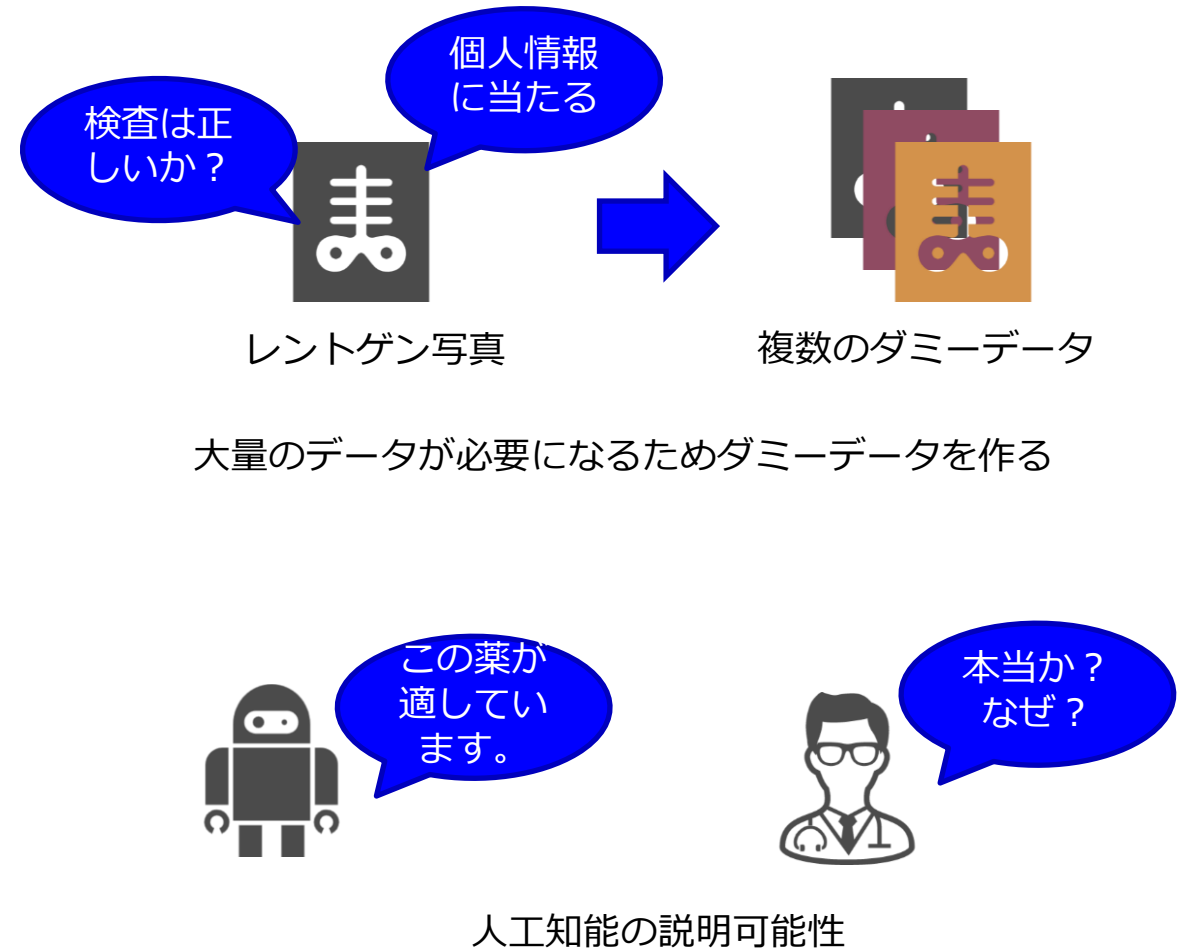
セキュリティ意識向上と教育プログラム

新しい技術やトレンド

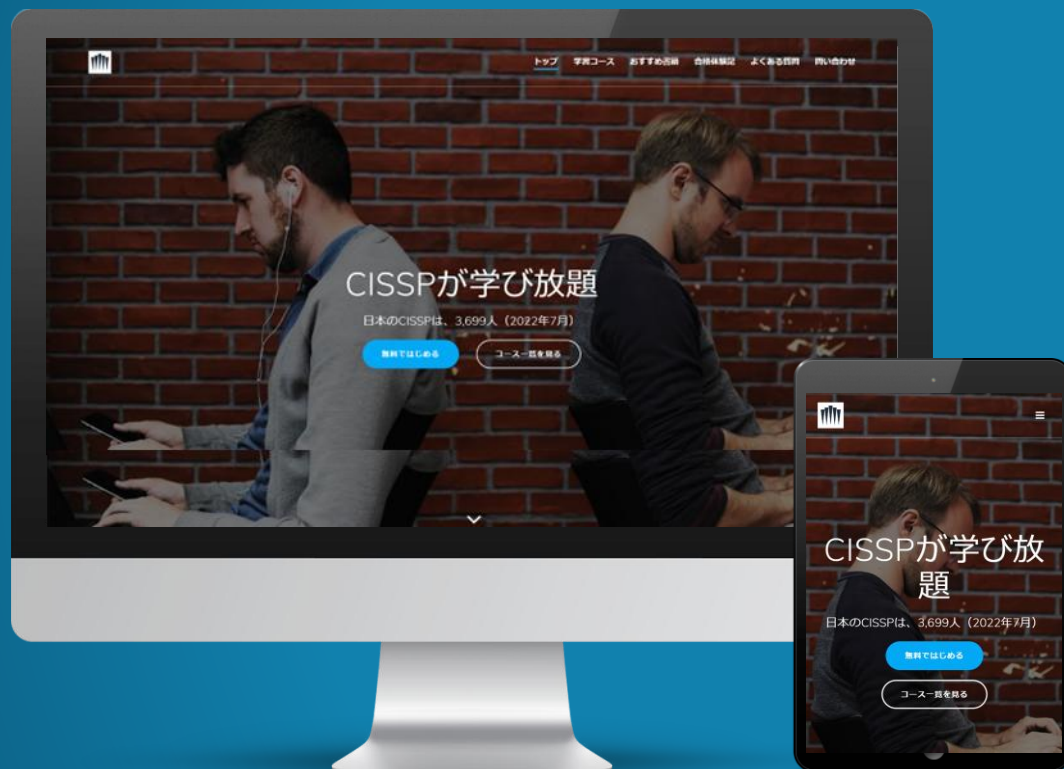
●ニューラルネットワーク

ディープラーニング（深層学習）の懸念

- ただし、ディープラーニングを行うには正解付きのデータを数万個用意する必要があります。つまり、事前に正解と判断する結果付きデータを、個人情報に保護された範囲で蓄積されている必要があり、医療などの分野によっては困難です。そのため、ダミーデータを扱うことで意図的にデータ数を増やす努力が行われます。
- また、ディープラーニングで得られた結果に対して、なぜその結果を選択したのかは説明されません。人工知能に対して、信頼し、納得する必要があります。AIの思考の理解しやすさを“説明可能性”と言います。



PIEDPINの紹介



なぜセキュリティを学ぶのか

セキュリティの最も大きな敵は、人はあらゆるもの事に慣れ、そのリスクを考えなくなる習性にあります。セキュリティの学びを通して得られる貴重なものは、あらゆる事象に対して好奇心を持つことであり、それは目まぐるしい現代を生きるのに大いに役立つでしょう。

- EASY DESIGN
- SUPER EFFICIENT
- EVERYWHERE

PIEDPINを選ぶ理由



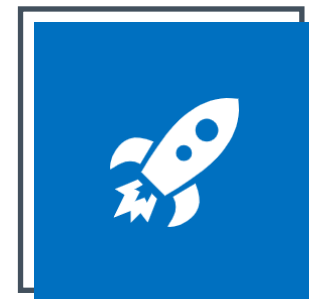
**EASY
DESIGN**

日本語で学べる



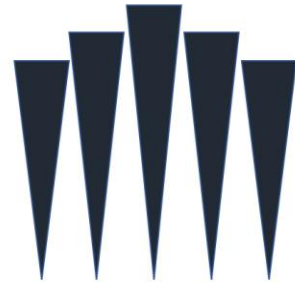
**SUPER
EFFICIENT**

わかりやすい説明



EVERYWHERE

どこからでも学べる環境



THANK YOU

Let's try CISSP!